



# Securing the Electronic Hardware Supply Chain: A Cost-Benefit Analysis Framework

A Pragmatic Approach to Balancing Security and Economic Efficiency

Arindam Goswami, Rijesh Panicker, Colonel KPM Das

Takshashila Discussion Document – 2025-07

Version 1.0, April, 2025

This discussion document proposes institutional changes and a comprehensive, quantitative, cost-benefit analysis-based Hardware Supply Chain Security (HSCS) framework to address the complex challenges of securing electronic hardware supply chains.

*Recommended Citation:*

Arindam Goswami, Rijesh Panicker, Colonel KPM Das, “Securing the Electronic Hardware Supply Chain: A Cost-Benefit Analysis Framework,” Takshashila Discussion Document – 2025-07, April, 2025, The Takshashila Institution.

© The Takshashila Institution, 2025

# Executive Summary

Electronic hardware supply chain security has emerged as a critical concern in security discussions at national and multilateral levels. This paper proposes a governance and institutional structure for implementing a systematic approach that balances national security interests with practical implementation considerations. This institutional mechanism must do the analytical work required to secure electronic hardware supply chains. This paper also recommends following an analytically rigorous, quantitative, cost-benefit analysis approach to analyse policy interventions before implementing them. It proposes transforming traditional subjective assessments into data-driven decision-making, enabling policymakers to evaluate specific product and use-case combinations based on sector criticality, a product's vulnerability, and policy severity requirements. It takes into account economic factors as well as implementation details. This is in contrast to the currently followed one-size-fits-all, ad hoc approach. The paper then proposes one such framework that combines harm prevention value, implementation costs, and strategic importance of sectors (based on the two parameters of criticality and vulnerability) to come up with a severity score, which helps decide the severity and details of a policy targeting a particular product's supply chain security.

This document has been formatted to be read conveniently on screens with landscape aspect ratios. Please print only if absolutely necessary.

## Authors

Arindam Goswami is a Research Analyst working in the High-Tech Geopolitics Programme at The Takshashila Institution.

Rijesh Panicker is a Fellow with the High-Tech Geopolitics programme at the Takshashila Institution.

Colonel KPM Das is an Adjunct Fellow with the Takshashila Institution and the National Cybersecurity and Trust Officer for Cisco.

## Acknowledgments

The authors would like to thank Pranay Kotasthane for his valuable comments and feedback.

# Table of Contents

|                                                            |    |
|------------------------------------------------------------|----|
| Executive Summary .....                                    | 2  |
| Table of Contents .....                                    | 3  |
| 1. Introduction .....                                      | 5  |
| 2. Problem Statement.....                                  | 9  |
| 3. Existing Policies and Approaches .....                  | 10 |
| 4. Approaches to Supply Chain Security .....               | 12 |
| 4.1 United States.....                                     | 13 |
| 4.2 European Union.....                                    | 14 |
| 4.3 United Kingdom .....                                   | 15 |
| 4.4 India.....                                             | 17 |
| 5. Why Focus on Product Security?.....                     | 21 |
| 6. Problems with Current Approaches.....                   | 23 |
| 7. A Converged and Unified Governance Mechanism .....      | 26 |
| 8. Cost-Benefit Analysis Framework .....                   | 36 |
| 9. Application to Use Cases .....                          | 39 |
| 9.1 Use-Case 1: Surveillance Cameras .....                 | 41 |
| 9.1.1 Scoring Framework .....                              | 44 |
| 9.1.2 Qualitative Assessment of Criticality.....           | 49 |
| 9.2 Use-Case 2: Telecom and Enterprise Class Routers ..... | 53 |

|                                                              |    |
|--------------------------------------------------------------|----|
| 9.2.1 Scoring Framework .....                                | 57 |
| 9.2.2 Qualitative Assessment of Criticality.....             | 61 |
| 10. Conclusion .....                                         | 65 |
| 11. Appendix.....                                            | 66 |
| 11.1 Criticality-Vulnerability Classification Framework..... | 68 |
| 11.1.1 What is Criticality? .....                            | 71 |
| 11.1.2 What is Vulnerability?.....                           | 72 |
| 11.2 Strategic Importance Coefficient .....                  | 75 |
| 11.2.1 National Impact (NI).....                             | 77 |
| 11.2.2 Replacement Difficulty (RD).....                      | 77 |
| 11.2.3 Strategic Vulnerability (SV) .....                    | 78 |
| 11.2.4 Geopolitical Implications (GI).....                   | 78 |
| 11.3 Cost-Benefit Analysis .....                             | 78 |
| 11.3.1 Total Implementation Costs .....                      | 79 |
| 11.3.2 Potential Harm Prevention (PHV) .....                 | 81 |
| 11.4 Risk Mitigation Efficiency Quotient (RMEQ) .....        | 86 |
| 12. References .....                                         | 91 |

# 1. Introduction

Hardware supply chain security refers to the comprehensive set of measures, controls, and practices designed to protect the integrity, authenticity, and security of hardware components and systems throughout their lifecycle – from design and manufacturing to deployment and disposal. It has two fundamental concerns: First, the risk of disruption in hardware availability and functionality due to geopolitical events, natural disasters, or market fluctuations. Second, the risk of intentional compromise through the insertion of malicious components, backdoors, or vulnerabilities at any point in the supply chain.

This implies that hardware needs to be secured from cyber-attacks and hacks into supply chains. Design, planning sourcing and manufacturing are initial stages in the life cycle that needs to be maker-checker reviewed. The latter stages of quality, delivery, sustenance, and end-of-life are equally important. It also implies that technical and process choices made in these eight stages rely on secure, trusted technologies and components. It also requires that hardware supply chain security is an assurance outcome, a dynamic interplay between technology, process, and people pillars. Figure 1 below indicates the eight-stage sequential hardware supply chain construct with associated risks.

The supply chain attacks<sup>1</sup> which took Hezbollah by surprise on 17 and 18 Sep 2024 are an example of a classic hardware supply chain attack. Even as the vector was kinetic in impact, this audacious attack owed its success to meticulous planning, capture of distribution channels and surgical delivery at points of interest.

The maker-checker concept is a control mechanism used in organisational processes where trust in a transaction is reinforced through peer reviews. In supply chain lifecycles, particularly in the design, planning, and sourcing stages, this mechanism strengthens the rigour and diligence of decisions.

Disclaimer on use of AI:

We have made use of large language model-based chat tools such as Claude and ChatGPT, in the development of this paper. AI tools have been used for:

- Reviewing the tonality of content and for providing alternatives in terms of writing style.
- Re-formatting of provided textual content into tabular format; see the scoring framework in section 9.

| Risks                                     | Stages |      |        |      |         |          |            |             |
|-------------------------------------------|--------|------|--------|------|---------|----------|------------|-------------|
|                                           | Design | Plan | Source | Make | Quality | Delivery | Sustenance | End-Of-Life |
| Intellectual Property (IP) Theft          | •      |      |        |      |         |          |            |             |
| Design Flaws                              | •      |      |        |      |         |          |            |             |
| Compliance and Standards Related Risks    | •      |      |        |      |         |          |            |             |
| Counterfeit Components                    | •      |      |        |      |         |          |            |             |
|                                           |        |      |        |      |         |          |            |             |
| Demand Forecasting Errors                 |        | •    |        |      |         |          |            |             |
| Resource Allocation                       |        | •    |        |      |         |          |            |             |
| Supply Chain Disruptions                  |        | •    |        |      |         |          |            |             |
|                                           |        |      |        |      |         |          |            |             |
| Supplier Reliability                      |        |      | •      |      |         |          |            |             |
| Cost Fluctuations                         |        |      | •      |      |         |          |            |             |
| Ethical Sourcing                          |        |      | •      |      |         |          |            |             |
| Geopolitical Risks                        |        |      | •      |      |         |          |            |             |
|                                           |        |      |        |      |         |          |            |             |
| Manufacturing Defects                     |        |      |        | •    |         |          |            |             |
| Equipment Failure                         |        |      |        | •    |         |          |            |             |
| Labour Issues                             |        |      |        | •    |         |          |            |             |
| Environmental Risks                       |        |      |        | •    |         |          |            |             |
|                                           |        |      |        |      |         |          |            |             |
| Inconsistent Quality                      |        |      |        |      | •       |          |            |             |
| Testing Failures                          |        |      |        |      | •       |          |            |             |
| Regulatory Non-Compliance                 |        |      |        |      | •       |          |            |             |
|                                           |        |      |        |      |         |          |            |             |
| Logistics Failures                        |        |      |        |      |         | •        |            |             |
| Inventory Management                      |        |      |        |      |         | •        |            |             |
| Cybersecurity Risks                       |        |      |        |      |         | •        |            |             |
| Counterfeit, Customs and Trade Compliance |        |      |        |      |         | •        |            |             |
|                                           |        |      |        |      |         |          |            |             |
| Maintenance Challenges                    |        |      |        |      |         |          | •          |             |
| Supply Chain Continuity                   |        |      |        |      |         |          | •          |             |
| Customer Support                          |        |      |        |      |         |          | •          |             |
| Obsolescence Management                   |        |      |        |      |         |          | •          |             |
|                                           |        |      |        |      |         |          |            |             |
| Environmental Impact                      |        |      |        |      |         |          |            | •           |
| Data Security                             |        |      |        |      |         |          |            | •           |
| Regulatory Compliance                     |        |      |        |      |         |          |            | •           |
| Asset Recovery                            |        |      |        |      |         |          |            | •           |

Figure 1: Eight Stages in a Supply Chain and the Associated Risks (Source: Authors' own representation)

Hardware supply chain security also includes the firmware and software that accompany the hardware. This is because hardware is often passive by itself, with firmware and software providing, quite often, the entry points for malicious actors. Only a connected hardware-software ecosystem is worth considering from the point of view of supply chain management and security.

Because of their very complex nature, hardware supply chains are highly diversified and involve multiple vendors and stakeholders. In effect, the number of potential points of entry for malicious actors leading to security compromises is very high. Due to this, understanding the entire supply chain is almost impossible for a single actor, and consequently, framing a coherent and logical security framework will be very difficult and time-consuming for a nation.

Consider the SolarWinds<sup>2</sup> supply chain attack of 2020. It underscored the interconnected risks of hardware and software security in modern information technology infrastructure. The compromised Orion network monitoring platform affected over 18,000 customers, including major US government agencies and Fortune 500 companies. The attackers inserted malicious code into SolarWinds' software updates, which then interacted with and compromised hardware components across networks. This highlighted how even seemingly trusted hardware can be exploited through software vulnerabilities, and revealed critical challenges in hardware supply chain security: the difficulty of detecting hardware compromises, the

The SolarWinds attack (2020) and the Log4j vulnerability<sup>3</sup> (2021) showed how deeply software dependencies can impact hardware security. Even if the hardware is clean, vulnerable software running on it can turn it into an attack vector.

Disclosures of the entire Hardware Bill of Material (HBOM) and Software Bill of Material (SBOM) is the first step towards transparency in the supply chain. These disclosures enable all the stakeholders including the suppliers and partners of customers to scope the problem.

inherent trust placed in vendor-supplied hardware and firmware, and the global attack surface created by interconnected supply chains.

Hardware supply chain security policies are, therefore, often subjective endeavours and are, more often than not, done in an ad hoc manner, without the quantitative and objective rigour that they deserve. There is, therefore, an urgent need for robust security policy frameworks in critical infrastructure, which can apply quantitative methodologies of cost-benefit analysis to evaluate policy effectiveness, leaving decision-makers with concrete metrics to balance competing priorities of national security and economic efficiency. In the following section, we enunciate this problem statement which has inspired the writing of this paper. The next section looks at existing policies and approaches around the world and in India, and what are some of the problems with them. We then provide our recommendations and our proposed quantitative framework. These recommendations also include the institutional and governance frameworks that should accompany the quantitative cost-benefit analysis framework that we have developed. We then conclude with an application of the framework to two use cases, and provide our recommendations for the same.

## 2. Problem Statement

The increasing complexity and global interdependence of technology supply chains, coupled with rising geopolitical tensions, has created an urgent need for robust security frameworks in critical infrastructure. While existing approaches to supply chain security often rely on subjective assessments and binary country-of-origin decisions, they fail to capture the nuanced interplay between trust, transparency, operational feasibility and operational security. The result is a one-size-fits-all approach that can cause more harm than benefit.

This research aims to address this gap by first, proposing a governance structure that can spearhead supply chain security policymaking and detailed analysis, and second, by recommending a data-driven, quantitative framework for performing cost-benefit analysis before deciding on any policy intervention.

The framework aims to transform subjective supply chain security assessments into data-driven decisions by mathematically synthesising harm prevention value, implementation costs, and strategic importance. The

resultant cost-benefit analysis should then provide a mechanism to evaluate the severity of policy required for particular use cases.

The research explores how this quantitative approach can be applied to evaluate specific product and use-case combinations, taking into account sector criticality and product vulnerability, while proposing an institutional governance structure for practical implementation. The aim is to provide policymakers and technology strategists with evidence-based tools to navigate the complex landscape of hardware supply chain security in an increasingly interconnected world.

### 3. Existing Policies and Approaches

In cybersecurity parleys between states and in multilateral fora, it is now obvious that the geopolitical and national security interests reflect in the specific supply chain assurance agenda prioritised by states. In this agenda, these priorities are defined differentially by member states; some place importance on countries of origin, others on countries of manufacture and many others on component level security parameters. Any which way, each of the priorities that concern the stakeholders need to be seen as a complex interdependent maze of factors. Also, the scale and size of the nations' digital eco-systems within which the impact of supply chain security is seen requires separating the critical infrastructure from the rest.

We believe that the security objectives of critical supply chains are best served when guided by five principles.

- One, assessment of trust of system/component sources require focus beyond geography and country of origin to factors of transparency, accountability and impeccable governance and probity standards;
- Two, trust in products stems from an explicit and evidence-based demonstration of inbuilt trust anchors, both in software and hardware;
- Three, even while supply chains and markets are global, there is assurance of best-in-class, globally accepted, supply chain security standards;
- Four, supply chain integrity risks must be managed, but cannot be eliminated entirely without unacceptable impacts on competing factors, such as cost, resiliency, and innovation; and
- Five, given increasing reliance on digital services, the sourcing of technology is one area of risk, but there are also significant and equally, if not more, risks requiring attention regarding who manages the network and how effectively threats are being prevented, detected, and responded to on an ongoing basis. This is to bring a balance between the product end of the supply chain security perspective to the operational/practice end of the supply chain perspective.

Constructing a regulatory framework to address this set of principles best to secure critical infrastructure is the subject of this paper.

Regulators around the world are veering around to place the lens on both the sources of supply (companies and original equipment manufacturers (OEMs)) and the products in equal measure. India proposed and put in place the Trusted Source-Trusted Product Framework where the source (company supplying) requires to first pass the test of “trust” before the products undergo screening for their architecture and veracity of their components, hardware and software both.

## 4. Approaches to Supply Chain Security

There are three broad approaches to regulating supply chains that are in practice; a few examples are as follows.

- Collaborative: The US has chosen a more collaborative, voluntary approach, seeking to create capacity and capability among various regulators and private players to assess and mitigate security risks. There is also a focus on funding research to develop technology and tools in this area.
- Top-Down: The EU approach is more coordinated and top-down in nature, with a heavy compliance burden placed on member states and participating entities.
- Simple and Light Touch: The UK approach is the most light touch and simply provides a broad set of principles for large private firms to follow in choosing their cybersecurity and supply chain practices.

We broadly describe the major regulations in these three regions below.

## 4.1 United States

The US Executive Order 14017 on Securing Supply Chains<sup>4</sup> covers the risks and security measures related to supply chains. Based on recommendations from the Department of Homeland Security (DHS), a new Supply Chain Resilience Center (SCRC) has been set up to aggregate and disseminate information on supply chain vulnerabilities and disruptions. Some of the core initiatives of this new division will be on evaluating port security in the US, specifically related to reducing risks from the widespread adoption of the People's Republic of China (PRC) National Transportation and Logistics Public Information Platform (LOGINK). The SCRC will also lead efforts with Australia and the UK to secure critical supply chains and create a trilateral monitoring system for ongoing supply chain threats.

A critical part of the SCRC mandate is to support R&D in the supply chain security space, with the Science & Technology Directorate supporting the development of tools for a Software Bill of Materials (SBOM) for key stakeholders. This effort supplements the existing Cybersecurity and Infrastructure Security Agency (CISA) Supply Chain Risk Management (SCRM) task force's efforts at creating a Hardware Bill of Materials (HBOM) template.

The CISA is responsible for securing critical ICT infrastructure in the US. It maintains a list of critical infrastructure entities (section 9 entities), which the SCRC has been tasked with reviewing and expanding as needed. While CISA is the central authority within the US government for cybersecurity and infrastructure protection, it would appear that the SCRC will be

With the US-China tech rivalry, nations are pushing for self-reliance in semiconductor manufacturing. That is another aspect of this entire hardware supply chain security issue. The US CHIPS Act<sup>5</sup> (2022) highlights these efforts to reduce foreign dependence on chip supply chains.

increasingly focused on the narrow area of securing and making resilient the supply chains that support the critical infrastructure.

## 4.2 European Union

The EU approach is a more harmonised and regulatory heavy approach, with the EU Supply Chain Directive<sup>6</sup> (NIS2) and the Cyber Resilience Act<sup>7</sup> (CRA) both having regulatory provisions covering supply chain security. Where the NIS2 directive is focused on improving the overall cybersecurity levels in the supply chains across the EU, the CRA is focused on establishing horizontal cybersecurity requirements for products.

The NIS directive operates at three levels of abstraction. At the top level, an EU level Coordinated Risk Assessment occurs, which assesses the level of risk of critical supply chains, in consultation with the European Union Agency for Cybersecurity (ENISA), which identifies risk mitigation plans and best practices to address vulnerabilities. The criteria for evaluation include the extent of dependence and use of ICT products and services in a supply chain.

The second level of assessment is at the level of the member state – a National Risk Assessment. This allows member states to extend the scope of the NIS2 directive to an entity not originally covered, depending on the criticality of that entity to the member state based on their assessment of risk. Finally, there is an Internal Risk Assessment which is performed at the level of entities,

which obliges them to conduct risk assessments of their own supply chains including those of their direct suppliers and service providers. This extends to assessing the quality of the supplier's cybersecurity practices.

The Cyber Resilience Act (CRA) is focused on establishing cybersecurity requirements for digital products (defined as products which can directly or indirectly connect to networks) and seeks to address two problems. One, the current low level of cybersecurity in products and a lack of ability for users towards accessing important information on security such as updates. A secondary goal is also to ensure that in conjunction with the NIS directives around entity level assessment, a cybersecurity focus is implemented across the supply chain from the design state, making final products and services more secure. The CRA is only focused on consumer devices to provide a mitigation to the risk of escalating cybersecurity attacks from consumer devices that may threaten other critical sectors. A different set of EU regulations cover critical sectors such as medical devices, defence and telecommunications.

## 4.3 United Kingdom

The UK has followed a principles-based, light touch approach towards security, with a National Cyber Security Centre (NCSC)<sup>8</sup> Supply Chain Security guidance document that defines 12 high-level principles for supply chain risk management. It lists the best practices for supply chain assessment

and cites several supply chain attack scenarios. Broadly, the principles suggest the following three areas for large firms. The first, is to identify critical assets requiring protection, developing comprehensive knowledge of suppliers and their security practices, and assessing potential vulnerabilities and threats throughout the supply chain. Second, is for firms to establish their security requirements, set minimum security standards, and incorporate security considerations into contracts. In addition, firms are expected to ensure these requirements cascade through the supply chain network. Third, firms are expected to drive ongoing security enhancement through awareness-building, incident response support, and promoting better security practices among suppliers to enable effective security collaboration.

Alongside the broad principles, there is the Defence Cyber Protection Partnership (DCPP)<sup>9</sup>, a joint effort by the Ministry of Defence and the industry to protect the defence supply chain and a supplier assurance framework (Common Criteria for Assessing Risk (CCfAR))<sup>10</sup> that specifically manages supply chain risk in government procurement. Additionally, as far as critical infrastructure is concerned, there is a sector-specific legislation called The Telecommunications Security Bill<sup>11</sup> 2020, Electronic Communications Security Measures<sup>12</sup> and Telecommunications Security Code of Practice<sup>13</sup> for the telecommunications sector.

## 4.4 India

In India, the office of the National Cyber Security Coordinator (NCSC) in the NSCS (National Security Council Secretariat) within the PMO manages and coordinates security of supply chains. The NSDTS (National Security Directive for Telecom Scheme)<sup>14</sup> is the directive which lays down the Trusted Source Trusted Product framework for Telecom supply chain security. The qualification required for deployment of any product in any telecom network (considered most critical among critical infrastructure segments) is done at two levels: First, the OEM needs to qualify as a Trusted Source for which the company governance structures, ownership, shareholding and details of manufacturing sites are reviewed before approval; Second, once the OEM is tagged as Trusted Source, each of the products needs to undergo the Trusted Product qualification, where a review of the components, their sources, details of manufacturing facilities, and details of their software development centres is done. All in all, it is a comprehensive process both from a hardware and software point of view.

The National Critical Information Infrastructure Protection Centre (NCIIPC) is India's nodal agency responsible for protecting critical information infrastructure in the country. NCIIPC operates under Section 70A of the Information Technology Act and reports to the National Security Advisor (NSA) through the National Technical Research Organisation

(NTRO). It has no operational responsibilities; more of advisory, guidance, policy and capacity building roles.

For the other critical infrastructure segments like Oil and Gas, Power, Government, Transportation, Financial and Healthcare, there are no regulations; however, entities in these segments refer to the NSDTS as the qualifying criteria for their products.

Additionally, the Department of Telecommunications has a National Centre for Communication Security (NCCS) which has a charter to conduct testing, certifying and auditing functions for telecom networks and telecom products through a regulation called COMSEC<sup>15</sup>.

Figure 2 below provides a snapshot of the regulatory framework for ICT products.

## Indian Security Regulations and Governance

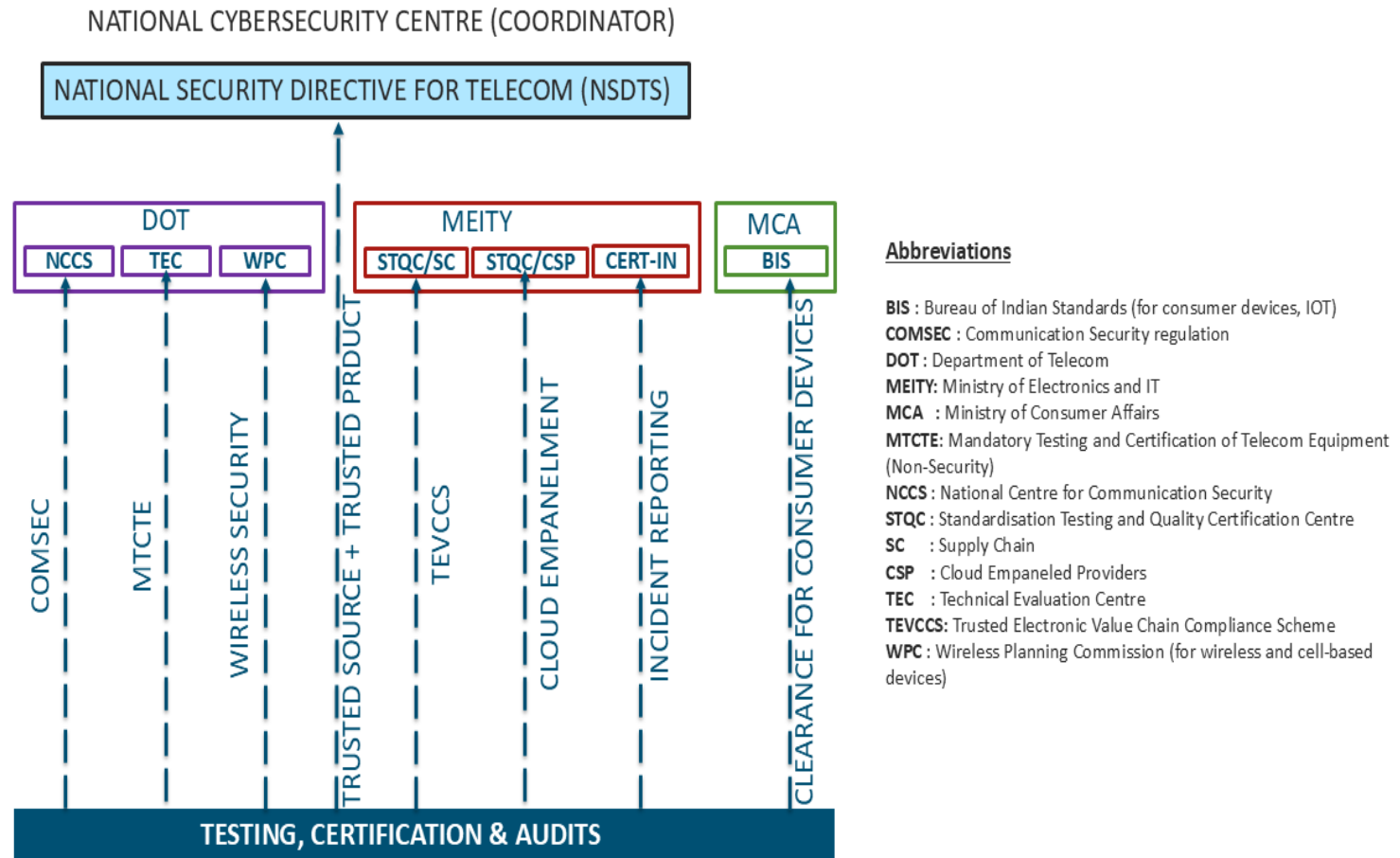


Figure 2: Existing Regulatory Framework for ICT products (Source: Authors' own representation)

As is evident from Figure 2 above, there is a multiplicity of regulations and directives, each of which is governed by a different ministry or department. This leads to inconsistencies in application of regulations in the market/field, for example, the same product deployed in a network in a bank will be governed differentially in the telecom sector.

The other faultline is that the regulatory agencies in different ministries are disparately governed – there is no single point of authority, accountability and responsibility at the national level. The NCSC is by its very title a “Coordinator” and not an “Authority”.

Before the NSDTS, India had issued the Public Procurement Order<sup>16</sup> of 2020, which amended the General Financial Rules 2017, to restrict public procurement from bidders in countries that share a land border with India. The order required bidders from such countries to register with the Competent Authority. The order was broad in its scope and coverage, covering all new procurements, all public sector units, and public-private partnerships. This shows how government policies can employ one-size-fits-all approaches.

## 5. Why Focus on Product Security?

The nature of the secure supply chain problem is such that it has many factors at play (often competing, and often not mutually exclusive) and current regulations find it a challenge to optimise the constraints in the absence of information on supply chains, and dependent market and operational factors. Broadly two perspectives emerge; one, that of objectively placing filters on the source of supply through a “trust” lens and two, that of looking at products outside of the context paying attention to just the design, security architectures and build practices. Both perspectives have their own place, and finding the right balance between the two is crucial to arrive at a regulatory framework which is “trust” anchored and is seen as credible and effective by all stakeholders; the regulator, the security agencies in the governments and the market players (product companies and service providers end-to-end in the supply chain).

Taking “trust” as being fundamental to security of supply chains, and from a product perspective, some of the cornerstones may include a few or more of the following:

- Products are trustworthy if you can identify and get traceability of the product and its component systems from design stage to the end-of-life stage, through the entire lifecycle, till its disposal.

- Products are trustworthy if there is an effective methodology to identify counterfeit in the supply chain.
- Products are trustworthy if they have the state-of-the-art accepted architectural security features. It also has research and standards collaboration on Post-Quantum Crypto and Internet of Things.
- Products are trustworthy if they can protect running devices from attacks that change product hardware performance and/or software execution. Built-in system protections exist that increase system resilience.
- Products are trustworthy if they are delivered through a transparent Secure Supply Chain, encompassing all—Design-Plan-Source-Make-Quality-Deliver-Sustain-End-Of-Life.

We also believe that focus must be on effective risk management. The goal should not be the elimination of all, but instead should focus on mitigation of any risk that is unacceptably high when the likelihood of the event is factored with the consequences of its occurrence. Therefore, a low probability event with a highly negative consequence might be equally worth preventing as a high probability event with a relatively low negative consequence. The key point, however, is that not all risks are actually worth bringing down to zero. Mandating that all product components must be from trusted sources, in order for the equipment supplied to be trusted, may seem to be a foolproof option. It is quite possible, however, that a passive

component could be tested and validated by a trusted entity for inclusion in even critical systems regardless of the trustworthiness of its original source. The reasons justifying this outcome may include limited sources of supply for that particular component. By contrast, an untrusted source might never be a reasonable source for active components, finished products, or as the operator of a critical service.

To summarise, a framework which seeks demonstration of “trust” – both by way of where the supply chain comes from or passes through (source) and what is sought to be secure (product) – may likely address the concerns of all stakeholders.

## 6. Problems with Current Approaches

The global landscape of hardware supply chain security policies reveals a complex and fragmented regulatory environment. Different regions approach supply chain security with fundamentally divergent strategies: the United States opts for a collaborative and voluntary approach, the European Union implements a highly coordinated top-down compliance model, the United Kingdom provides a light-touch principles-based guidance, and India adopts a sector-specific restrictive framework. These inconsistent approaches

create significant challenges for multinational technology companies navigating diverse regulatory landscapes. There is a lack of comprehensive, uniform assessment mechanisms. The coverage of critical infrastructure sectors is incomplete, and the path is often not clear for individual industries and government departments. Most importantly, there is an absence of quantitative risk assessment frameworks with an overreliance on subjective evaluation criteria.

In India specifically, the policy challenges are particularly acute. While the telecom sector benefits from a comprehensive Trusted Source-Trusted Product framework that examines company governance, ownership, and manufacturing details, other critical infrastructure sectors like Oil and Gas, Power, Government, Transportation, Financial, and Healthcare remain largely unregulated. Entities in these sectors informally reference telecom guidelines, creating a patchwork of inconsistent security practices that fail to address sector-specific technological risks.

Globally, current hardware supply chain security policies suffer from profound structural weaknesses. They predominantly rely on static compliance checklists, lack real-time threat evaluation mechanisms, and fail to integrate emerging geopolitical risks. The policies often prioritise bureaucratic compliance over genuine security, creating administrative burdens without proportional security improvements. By over-emphasising principles like country of origin and ownership structures, these approaches

neglect critical aspects of technological security such as operational practices, network management capabilities, operational overheads and threat detection mechanisms. These various tangible and intangible factors need to be weighed into a comprehensive framework that can give very precise policy outputs that are simple to decide.

The fundamental problem lies in the policies' narrow and inflexible approach to trust assessment. Most current frameworks concentrate on surface-level attributes like hardware and software bill of materials, manufacturing locations, and ownership details, while overlooking the complex technological ecosystems in which these components operate. They struggle to balance the competing priorities of innovation, cost, and security, resulting in either too restrictive or insufficiently protective policies.

Technological capability gaps further compound these challenges. There is limited investment in developing advanced quantitative assessment technologies, insufficient funding for supply chain security research, and weak mechanisms for continuous technological validation. The policies fail to recognise the dynamic nature of technological risks, treating supply chain security as a static problem rather than an evolving landscape. The governance and institutional mechanisms lack clarity, are not well-thought-out or even comprehensive.

What emerges is a clear need for a new approach to hardware supply chain security. Such a framework must be quantitative, mathematically rigorous, and capable of dynamic risk assessment. It should move beyond binary trust evaluations to multi-dimensional security assessments that consider operational practices, technological capabilities, and geopolitical contexts to come up with rigorous cost-benefit analysis that can feed into policy. By investing in continuous research, data collection and analysis, and creating flexible, sector-agnostic evaluation mechanisms, policymakers can develop more effective strategies for managing the complex risks inherent in global technology supply chains.

## 7. A Converged and Unified Governance Mechanism

We propose that the present National Cyber Security governance organisation as given in Figure 3 below be recast to address the realities and imperatives of supply chain security. Presently, the charter to lay down policies for supply chain security rests with the Ministry of Electronics and Information Technology (MEITY), even as their proposed regulation titled “Trusted Electronic Value Chain Compliance Scheme” has been in the cold storage for over five years. This delay may be due to many factors – lack of direction and agency at the top level to bring together all ministries and

departments to sign-off on a unified and harmonised nation supply chain security regulation is one such possible factor. Geopolitical dynamics in India's immediate neighbourhood and increasing instances of cyberattacks on strategic information infrastructure may have led to the announcement of the National Security Directive for Telecom Scheme (NSDTS) by the National Security Council Secretariat in December 2020. This directive from the NSA's own office highlights the strategic vulnerabilities that plague the national critical information infrastructure, including Telecom, Govt, Oil and Gas, Transportation, Power, Healthcare and Banking. Telecom carries the digital lifelines for all of these strategic sectors, and hence is singled out as a priority for review of supply chain security.

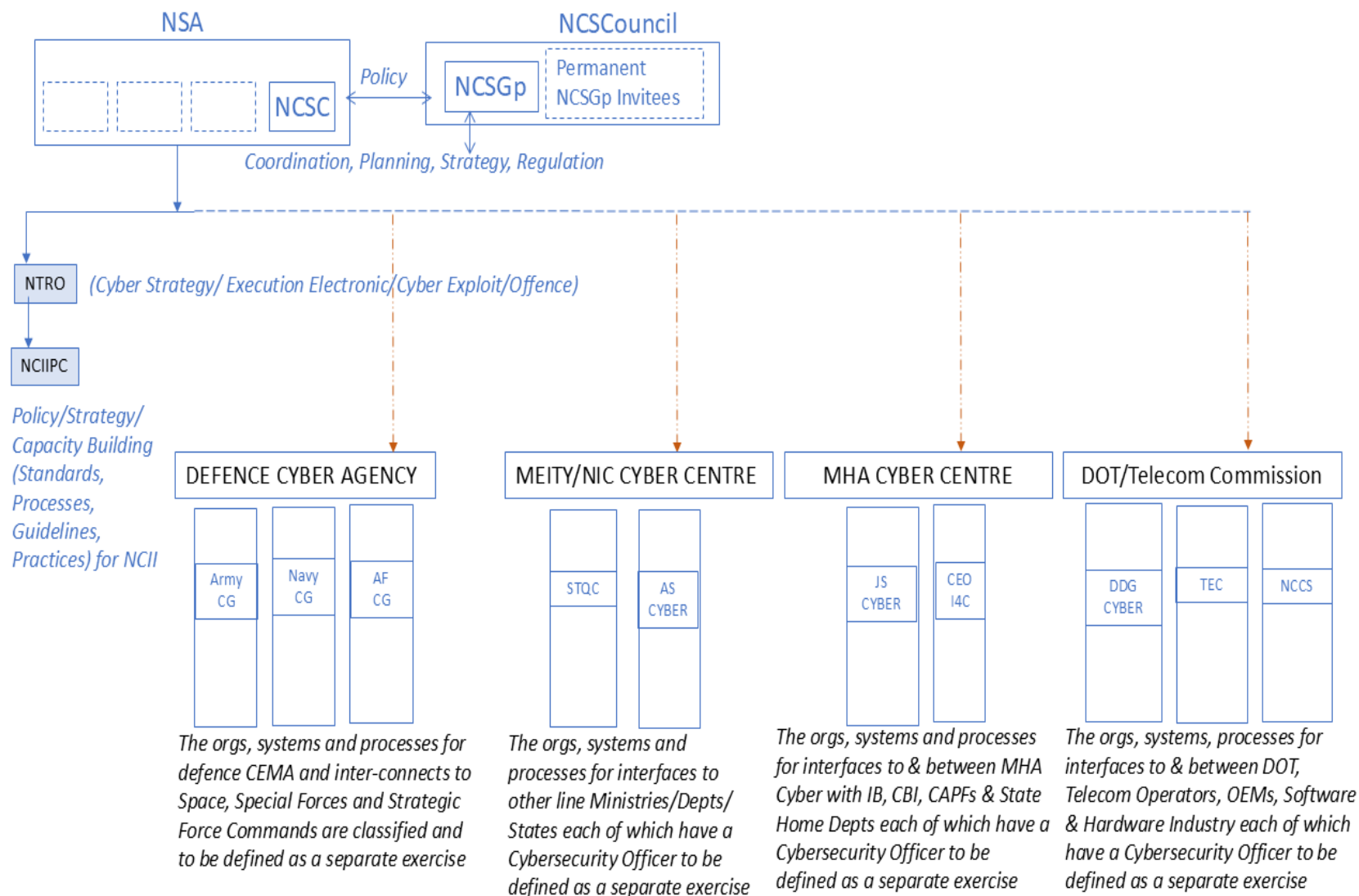


Figure 3: Existing National Cyber Security Governance Structure (Source: Authors' own representation)

Abbreviations:

NSA: National Security Adviser

NCSC: National Cyber Security Coordinator – charged with coordination and reporting

NCSGp: National Cyber Security Group (Permanent NCSGp invitees include experts, industry members and civil society representatives)

NCSCouncil: National Cyber Security Council

NCII: National Critical Information Infrastructure

NTRO: National Technical Research Organisation

NCIIPC: National Critical Information Infrastructure Protection Centre

CERT: Computer Emergency Response Team

CERT-IN: Indian Computer Emergency Response Team

TEC: Technical Evaluation Centre

NCCS: National Centre for Communication Security

STQC: Standardisation Quality and Certification Centre

AS: Additional Secretary

JS: Joint Secretary

CG: Cyber Group

DDG: Deputy Director General

CERT: Computer Emergency Response Team

MEITY: Ministry of Electronics and Information Technology

NIC: National Informatics Centre

DOT: Department of Telecommunications

MHA: Ministry of Home Affairs

CEO I4C: Chief Executive Officer, Indian Cyber Crime Coordination Centre

NCRC: National Cybersecurity Response Centre

NCRC-O: NCRC-Offensive

NCRC-D: NCRC-Defensive

CEMA: Cyber and Electromagnetic Activities

IB: Intelligence Bureau

CBI: Central Bureau of Investigation

CAPF: Central Armed Police Forces

OEM: Original Equipment Manufacturer

Expectations from the regulators have changed from an implicit acceptance of trust in products to a demand for explicit demonstration of trust. Also, this has led to an understanding that the state governance mechanisms and its regulators need to build capacities to secure the supply chains. There is now a need for a single governance node which is accountable, responsible and authorised/vested-with-powers to govern cybersecurity. This need reflects in an integrated policy-making and execution organisation.

We propose that significant enhancement of the governance framework is required to factor in the threats from supply chains and dynamics between these threats and responses from the national security agencies. In case of strategic cyber incidents where all-of-agency response is needed, we propose a “Command” model as is the practice in the US. Most critical cyber security agencies should be controlled under a unified command structure as given in Figure 4 below.

We propose that a National Cyber Command (NCC) be established as the apex cybersecurity operational node under the NSA which will be responsible for strategy, policy, planning and operations across Indian cyberspace. The NCC has the authority, responsibility and accountability for all matters related to assurance, resilience, defence and intervention in cyberspace. NCC is expected to orchestrate national cyber agencies and resources across Centre and States, as well as across Central Ministries and Departments towards national cyber outcomes.

We further propose that a technical team called the SCTO (Supply Chain Technical Office) under the NCSC (National Cyber Security Coordinator) be established which is solely focused on supply chain security, and chartered to secure and establish visibility into supply chains leading into the critical infrastructure entities as listed by the National Critical Information Infrastructure Protection Centre (NCIIPC). Functionalities will get built on

top of this system. There should be regulatory and policy certainty and consistency, otherwise innovation in this field will be scuttled.

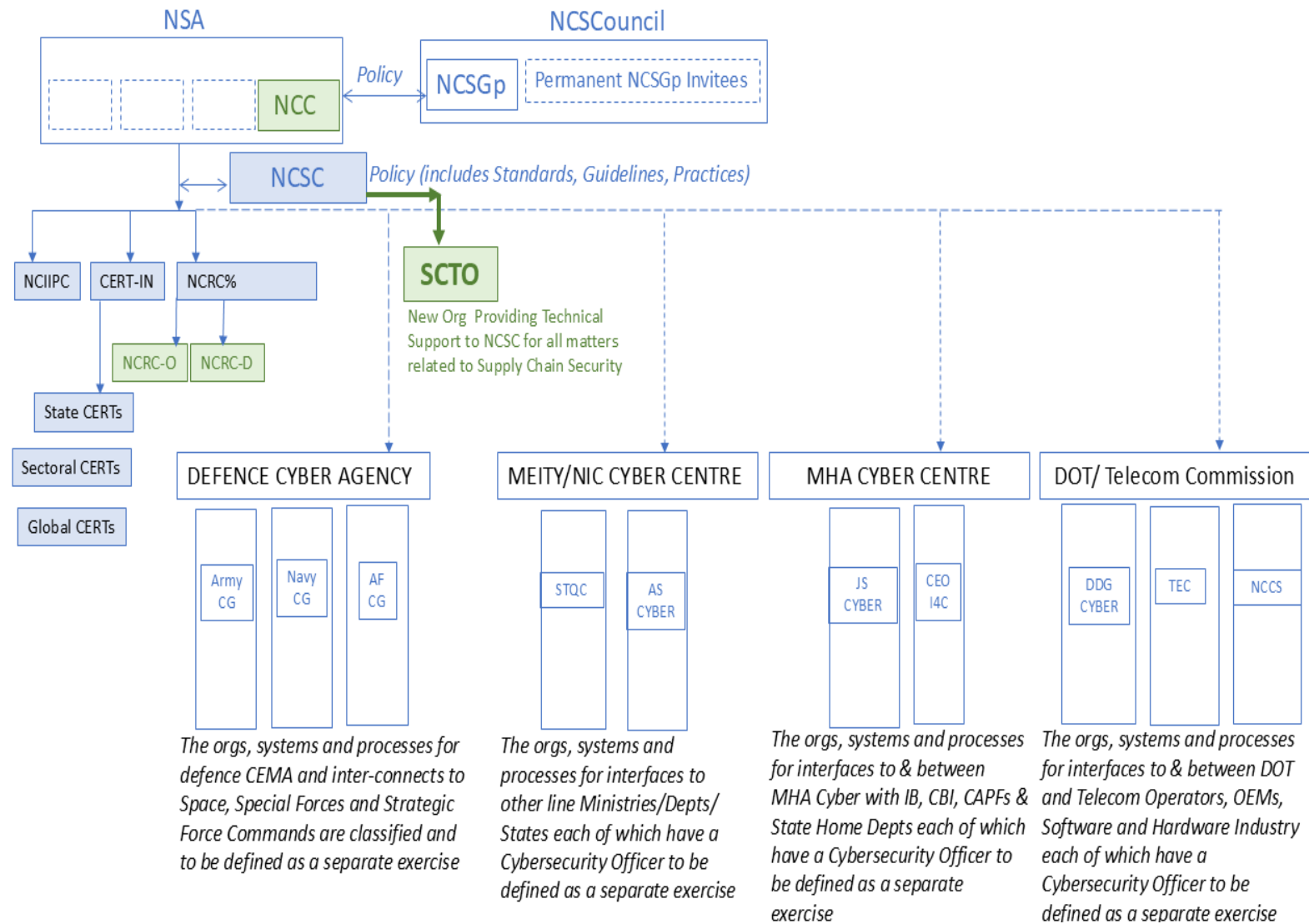


Figure 4: Proposed National Cyber Security Structure with new organisations highlighted in green (Source: Authors' own representation)

Abbreviations:

NCC: National Cyber Command

SCTO: Supply Chain Technical Office

NCRC: National Cybersecurity Response Centre

NCRC-O: NCRC-Offensive

NCRC-D: NCRC-Defensive

Rest all abbreviations as mentioned under Figure 3.

This agency must look at supply chain security at both macro level as well as micro level. At the macro level, the agency provides the set of principles which will be annexed as Secure Supply Chain Guides for the critical infrastructure organisations in both public and private sector. Trust is the defining factor of a secure supply chain. To ensure trust, the governance, transparency, accountability and architectural aspects of the supply chain need to be addressed. At the macro level, this implies defining what a trusted source is and laying down the requirements that a source must comply with.

At a micro level, this agency should be equipped and staffed with deep technical and security expertise to lay down and define the secure supply chain assurance requirements for each of the classes of product families. These requirements may eventually be tested, certified and audited to provide the transparency that a user requires.

The other task of this technical team, SCTO, will be to collect data and information that will help feed into the framework proposed in this paper. This data collection will have to be done from various sources and

stakeholders – industry, government departments, etc. The team will then form a view about the various parameters expected in the cost-benefit analysis framework, feed them into the framework, and come up with the final estimate about the severity of policy prescription required for the sector and product in question.

To do all of the above analytical work, this team will have to be filled with sector experts, technical experts, representatives from the ministries and departments concerned, industry representatives, and others that the NCSC determines as required.

It is recommended that Supply Chain Security being multi-segment, and requiring multi-ministry/department coordination, the role of the Technical Agency to be the regulator for Security of Supply Chains called the SCTO is best placed within the NCSC.

We believe that NCRC-O and NCRC-D are existing functionaries in the governing structure to cyber-secure national strategic assets, through offensive and defensive measures. This paper acknowledges the strategic need of their functions and recommends bolstering these functions.

Apart from this, this agency should also help India participate in setting global standards in supply chain security. India should continue actively participating in ITU, Common Criteria and 3rd Generation Partnership

Project (3GPP)<sup>17</sup> fora with lead technical agencies like TSDSI and other Govt and industry associations. Additionally, India is an active participant in ISO-related standards building exercises.

We propose that decision-making with regard to electronic supply chain security policy should be based on a cost-benefit analysis framework that is analytically rigorous and quantitative in nature, instead of just being qualitative and subjective. This framework should evaluate the criticality and vulnerability of the particular set of technologies, use cases and contexts under consideration, the costs involved in implementing the policy, the harm that can be prevented by the policy under consideration and the strategic importance of the specific sector or use-case being evaluated. This framework's output should be recommendations for the type and severity of policies that need to be enacted for various scenarios. This will make the decision-making process much more data-driven and analytically rigorous.

This whole process of analysis needs to be very comprehensive, and not ad hoc. It needs thinking about minimum baseline security standards which would entail taking a comprehensive look at security, which includes what happens when a product is installed and turned on and a way to consider system security. For instance, the Department of Telecom has a charter to engage with telecommunication service provider licensees. These licences could consider having annexures specifically related to security and the framework of Minimum Baseline Security Standards can additionally include

secure supply chain operational best practices. Apart from these minimum standards, the agency needs to come up with sector specific and use-case specific additions that will consider each context differently.

## 8. Cost-Benefit Analysis

### Framework

In this section, we propose the outline of the cost-benefit analysis that the new organisation, SCTO (proposed in the previous section), should carry out for critical sectors and use cases or products that it identifies in coordination with NCIIPC and other stakeholders. This section talks about the higher-level principles and parameters that such an analysis should focus on, leaving the actual quantitative details open for further discussion. The paper does, however, propose one such quantitative approach later in the Appendix, and applies that to two use cases in Section 9.

As mentioned above, any policy action related to hardware supply chain security needs to be preceded by a thorough data-driven cost-benefit analysis, which is quantitative as well as qualitative.

It should evaluate the following:

- The comprehensive implementation costs of any policy intervention.

- The harm prevention value to be derived from that action.
- The strategic importance of the particular sector or use-case or scenario.
- Criticality of the sector and vulnerability of the product, thought of in a combined manner, and not individually or in isolation.

The parameters mentioned in the last two points – strategic importance, criticality and vulnerability – are required to normalise both the benefits and costs of any policy action by the essential characteristics of the use cases, products and scenarios under consideration. This normalisation further makes the assessment objective and context-specific, and moves away from a one-size-fits-all approach.

This analysis should then provide concrete recommendations for the type and severity of policies that need to be enacted for various scenarios. The unique contribution of this paper is to propose different policy actions for different product and use-case combinations, taking into account various quantitative assessments and doing as comprehensive and objective an analysis as possible.

Corresponding to the severity output of the framework, the paper recommends the following types of actions:

**Low Risk (No Restrictions) Approach:** In scenarios with minimal security risks, hardware supply chain policies can adopt a lightweight, non-interventionist stance. Organisations can procure and integrate technologies with standard market protocols, without additional regulatory overhead. The focus remains on maintaining normal market dynamics, trusting existing quality control mechanisms and standard industry practices. These environments typically represent stable technological ecosystems with predictable supply chain behaviours and low potential for strategic disruption.

**Medium Risk (Voluntary Certification) Strategy:** When potential vulnerabilities emerge, a balanced regulatory approach takes precedence. Voluntary certification programs are introduced, creating standardised security assessment frameworks without mandating strict ex-ante compliance. Organisations receive incentives to participate in security audits, with retrospective verification mechanisms. Soft enforcement through penalty provisions encourages proactive risk management. This approach transforms security from a compliance burden to a collaborative improvement process, allowing for flexibility while establishing clear accountability standards.

**High Risk (Trust but Verify) Protocol:** As technological and geopolitical risks intensify, a more stringent "trust but verify" model becomes critical. Comprehensive ex-ante checks are implemented before technology integration, focusing on pre-emptive risk identification. Whitelisting

becomes a key strategy, where only pre-verified technologies, suppliers and points of origin gain market access. Extensive due diligence, including detailed supply chain mapping, technological vulnerability assessments, and rigorous certification processes, becomes mandatory. The approach balances openness with strategic prudence.

**Very High Risk (Restrictive) Response:** In scenarios of extreme strategic vulnerability, hardware supply chain policies transition to a protective, exclusionary model. Access is systematically restricted from nations or entities deemed high-risk, utilising comprehensive blacklisting mechanisms. Critical technologies face complete blockades, with multi-layered screening preventing potential technological infiltration. National security considerations override market considerations, creating a fortress-like approach to technological sovereignty. The primary objective here shifts from market optimisation to strategic defence and technological independence.

## 9. Application to Use Cases

In the earlier section, of the factors discussed, we covered Vulnerability and Criticality as two key factors to be applied in arriving at recommendations for regulation and compliance. We have taken two use cases as examples: Surveillance Cameras (High Vulnerability, mostly Low Criticality) and

Routers (High Vulnerability, High/Very High Criticality) and arrived at a set of recommendations on their security controls and regulatory scope.

In these use cases, we provide two ways of looking at the problem. Refer to the appendix for the analysis framework used in this section for the two use cases. First, using our scoring framework outlined in the appendix, we arrive at a broad Strategic Importance Coefficient (SIC) for the product, which provides some guidance on broad ways to regulate the product. However, this alone is not enough. As we show with our Vulnerability–Criticality Framework, it is important to consider the context where a product is being applied.

To account for differences in context that can change the criticality, we also present a qualitative table that considers how each product may require different policy measures based on where it is being used. In the qualitative analysis, we look at the criticality and vulnerability of the product–use–case combination.

Please note that this is only an indicative list of recommendations, intended to show how the framework can be applied to come up with the severity of policies that are required for the particular sector–product use–case.

Let's now examine the two use cases of surveillance cameras and routers. We have applied the framework and parameters outlined in the appendix to both these use cases.

## 9.1 Use-Case 1: Surveillance Cameras

Security cameras are inherently of a connected nature and have complex supply chains, involving multiple vendors spread globally, particularly concentrated in East Asia, handling components from image sensors to processors and memory units. This geographical concentration creates both geopolitical and security risks.

The devices' network-connected nature, combined with regular firmware updates and integration into larger security systems, creates multiple attack vectors. A security breach can have severe consequences, from privacy violations to compromised physical security systems.

What about the recovery process? These are highly interconnected systems. The complex supply chains mean that the costs of system-wide replacements are high. Most regions outside East Asia show low self-sufficiency in camera manufacturing. There are limited domestic alternatives for key components, which means that a strategic redesign of supply chains is going to be hard to achieve and will take a long time. It is also essentially an economic activity, and thus can't be driven just by security imperatives.

There is a significant barrier in terms of accessing intellectual property. The intellectual property embedded in image processing algorithms faces significant risks of theft and reverse engineering, and is, therefore, very closely guarded. Hardware designs are also very protected intellectual property. These factors add to the vulnerability of cameras.

While individual camera replacement costs may be moderate, system-wide replacements involve substantial reconfiguration, integration, and security certification costs. What could reduce this cost is to identify the criticality of sectors where this replacement needs to be made, and only do it in the more critical sectors. That would narrow down the surface area of disruption.

So, overall, the above factors lead to a high vulnerability score for this product in whatever use-case it is fitted into. Consequently, the SIC will be higher for this use-case, even if it is in a strategically less important sector. That will then lead to a higher Risk Mitigation Efficiency Quotient (RMEQ) value (Refer to the appendix for RMEQ) (medium to high), which would mean more recommendations from the “trust but verify” category, even if they are ex-post checks for medium RMEQ category. The actual RMEQ value will depend on the answers to questions posed in the appendix. That will require a lot of data to be collected and analysed, something the proposed SCTO team should be working on. Questions for which it is difficult to get objective answers would need to be answered in a subjective manner, typically based

The Risk Mitigation Efficiency Quotient (RMEQ) measures the effectiveness of security investments by comparing the potential harm prevented against the total implementation costs, weighted by the strategic importance of the system. It provides a normalised score that helps decision-makers evaluate the value of security interventions relative to their complexity and strategic significance. Please refer to the appendix for a more detailed explanation of RMEQ.

on the vulnerability of that particular product. That, multiplied by the criticality of the sector, will give us the range of answers for that particular question.

For this particular product, since its vulnerability is high with regard to its supply chain structure, the resulting RMEQ will most likely be medium to high, which is what we have used to come up with our recommendations for this use-case, even if it is for low strategic sectors.

Having said that, let's look at how this use-case stacks up against some of the parameters and questions posed in the appendix, to get an idea about how this exercise would go for each question. For implementation costs, surveillance cameras present moderate administrative and operational challenges such as, for instance, the staff hours required for compliance documentation and security certification would be manageable, though not insignificant. The procurement delays would be moderate to high since the supply chains are somewhat concentrated in East Asia and there are not too many replacement options. Component costs would see a medium increase when sourcing from secure suppliers, while supplier substitution costs would be moderate except for the relatively standardised components of the camera technology. When examining threat probability, surveillance cameras show high vulnerability due to numerous attack vectors through network connections and firmware. The time between vulnerability discovery and patching tends to be concerning, often extending to weeks or months. The breach impact analysis

reveals moderate financial losses from system downtime, though these are usually localised. Operational disruption would be significant but not catastrophic, as most facilities have backup security measures. The reputational damage from breaches would be moderate, primarily affecting specific facilities rather than entire sectors. From a national security perspective, while sensitive information could be compromised, the impact would typically be confined to specific surveillance zones rather than affecting broad national infrastructure.

In the following sections, we have tried putting all of this through our framework to show how this framework is supposed to work, and come up with recommendations for this use-case at the end.

### 9.1.1 Scoring Framework

| Metric               | Qualitative Analysis                                                                                                                             | Score |
|----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|-------|
| Vulnerability Rating | Cameras are connected devices with frequent firmware updates; multi-vendor supply chains (mainly from East Asia) create multiple attack vectors. | High  |

|                                            |                                                                                                                                                                |                |
|--------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------|
| Criticality Rating                         | Most deployments (e.g., in public areas and educational institutions) are non-mission-critical, though government/healthcare uses raise importance moderately. | Low/<br>Medium |
| Strategic Importance Coefficient           | Derived from factors like National Impact and Replacement Difficulty; reflects moderate strategic importance for mixed deployment scenarios.                   | 0.4            |
| Total Implementation Costs                 | Moderate administrative, operational, and supplier substitution costs associated with compliance and testing.                                                  | 0.5            |
| Threat Probability                         | High likelihood of breach due to multiple network entry points and patching delays.                                                                            | 0.6            |
| Breach Impact (Potential Security)         | Moderate-to-high impact if breached, with risks including privacy violations and localised operational disruptions.                                            | 0.75           |
| Potential Harm Prevention (PHV)            | Calculated as Threat Probability $\times$ Breach Impact.                                                                                                       | 0.43           |
| Risk Mitigation Efficiency Quotient (RMEQ) | Computed using: $(PHV / \text{Total Costs}) \times SIC = (0.43 / 0.5) \times 0.4$ , indicating an overall medium risk level.                                   | 0.33           |

Table 1: Scoring framework for Use-Case 1

1. Strategic Importance Coefficient (SIC) (Overall  $\approx 0.38-0.40$ )

| Component                      | Qualitative Analysis                                                                  | Weight | Score            |
|--------------------------------|---------------------------------------------------------------------------------------|--------|------------------|
| National Impact (NI)           | Impact is relatively low as camera failures are not catastrophic at a national level. | 0.3    | 0.3              |
| Replacement Difficulty (RD)    | Cameras are comparatively easy to replace.                                            | 0.2    | 0.4              |
| Strategic Vulnerability (SV)   | Moderate risk from privacy and intellectual property concerns.                        | 0.3    | 0.5              |
| Geopolitical Implications (GI) | Limited geopolitical impact as these are not considered strategic assets.             | 0.2    | 0.3              |
| <b>Overall SIC</b>             |                                                                                       | —      | $\sim 0.38-0.40$ |

Table 2: SIC for Use-Case 1

2. Total Implementation Costs (Overall  $\approx 0.50$ )

| Component               | Qualitative Analysis                                    | Weight | Score |
|-------------------------|---------------------------------------------------------|--------|-------|
| Administrative Expenses | Moderate costs for compliance documentation and audits. | 0.4    | 0.5   |
| Operational Time Costs  | Procurement and testing delays are moderate.            | 0.3    | 0.6   |

|                             |                                                             |     |      |
|-----------------------------|-------------------------------------------------------------|-----|------|
| Supplier Substitution Costs | Availability of alternative suppliers keeps costs moderate. | 0.3 | 0.4  |
| <b>Overall Cost</b>         |                                                             | —   | 0.50 |

Table 3: Total Implementation Costs for Use-Case 1

### 3. Threat Probability (Overall $\approx 0.60$ )

| Component                         | Qualitative Analysis                                    | Weight | Score |
|-----------------------------------|---------------------------------------------------------|--------|-------|
| Attack Vectors                    | Multiple network entry points due to connectivity.      | 0.5    | 0.7   |
| Patching Delay                    | Some delays in applying firmware patches increase risk. | 0.5    | 0.5   |
| <b>Overall Threat Probability</b> |                                                         | —      | 0.60  |

Table 4: Threat Probability for Use-Case 1

### 4. Breach Impact (Overall $\approx 0.72$ )

| Component              | Qualitative Analysis                                                 | Weight | Score |
|------------------------|----------------------------------------------------------------------|--------|-------|
| Financial Impact       | Localised breaches can lead to moderate financial losses.            | 0.3    | 0.7   |
| Operational Disruption | A breach can cause significant disruption in affected installations. | 0.3    | 0.9   |

|                              |                                                           |     |      |
|------------------------------|-----------------------------------------------------------|-----|------|
| Reputational Damage          | Moderate impact on the reputation of specific facilities. | 0.2 | 0.7  |
| National Security Impact     | Limited effect at the national level.                     | 0.2 | 0.5  |
| <b>Overall Breach Impact</b> |                                                           | —   | 0.72 |

Table 5: Breach Impact for Use-Case 1

A RMEQ of 0.33 places surveillance cameras in the medium risk band (threshold: 0.26–0.5).

Broad recommended policies include:

- Strengthening vendor and supply chain vetting
- Implementing rigorous acceptance testing and certification (e.g., mandatory HBOM/SBOM reviews)
- Adopting “trust but verify” protocols with regular reassessment

The criticality score for cameras is estimated at a low 0.4 due to the widespread nature of its deployment. However, to account for differences in context of deployment, we also provide below an assessment of variances in criticality and possible remediation measures for each deployment context.

## 9.1.2 Qualitative Assessment of Criticality

| CONSIDERATIONS ON CRITICALITY BY USE-CASE: SURVEILLANCE CAMERAS |                                                       |                                             |                                |
|-----------------------------------------------------------------|-------------------------------------------------------|---------------------------------------------|--------------------------------|
| Criticality                                                     | Context /Deployment                                   | Market Factors                              | Risk Considerations            |
| Low                                                             | Public Places                                         | Many supply options<br>Low cost of sourcing | Privacy Risk/Surveillance Risk |
|                                                                 | Educational Institutions /<br>Healthcare Institutions | Low cost of support/maintenance.            | Privacy Risk                   |
|                                                                 | Manufacturing                                         |                                             | Industrial Espionage           |

|               |                                       |                                                                                                                                        |                                              |
|---------------|---------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------|
| <b>Medium</b> | Telecom Installations                 | Many supply options                                                                                                                    | Espionage/Loss of communication capabilities |
|               | Govt Installations                    | More rigorous deployment processes                                                                                                     | National Security risk/Sabotage              |
|               | Oil, Gas, Power, Water Installations  | Higher cost of sourcing and support options<br><br>Rigorous operational processes<br><br>Rigorous acceptance testing                   | National Security Risk/Sabotage              |
|               | Nuclear Plants/ Defence Installations | Limited options of sources<br><br>High standards and specs<br><br><i>Localise standards or global best-in-class, ensure only those</i> | National Security Risk/Sabotage              |

|      |                                        |                                                                                                                                                          |                                                     |
|------|----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------|
| High |                                        | <i>protocols are used which meet security standards.</i><br><br><i>Security hardened, no unused interfaces, no unused software or hardware component</i> |                                                     |
|      | Strategic Tech Research, Manufacturing | Higher cost lifecycle<br><br>Customised sensitive operational processes                                                                                  | Espionage/ Loss of critical technological advantage |

Table 6: Use-Case 1: Surveillance Cameras – Analysis and Recommendations

Based on the qualitative assessments above of the various deployment contexts for surveillance cameras, we suggest choosing a subset or combination of the recommendations below based on the criticality and other relevant factors.

### 1. Low Criticality

- a. Leverage diverse supply sources following ISO/BS Standards.
- b. Vet the antecedents of the maintenance vendors before onboarding. Include patching and security upgrades in the contract.

- c. When making RFPs or RFIs, focus on Technical Performance as much as Commercial Pricing.
- d. Carry out acceptance testing of products, deploy them in a test bed before final deployment.

## **2. Medium Criticality**

- a. Leverage diverse supply sources following ISO/BS Standards; Ensure functionally the products just remain cameras and have no active network component.
- b. Vet the antecedents of the maintenance vendors before onboarding. Include patching and security upgrades in the contract.
- c. Configuration Review for Security; Redundancy both in the hardware and in the network; Establish secure admin access.
- d. MBSS Minimum Baseline Security Requirements as part of Operational Processes; Risk Management Practices; Set up Controls; Audit periodically.
- e. Both offline and in-network testing; Firmware version validation; Maintain test records.
- f. Certification of the specific products; Ministry/Dept notifies approved products.

## **3. High Criticality**

- a. Product Security Requirements. Develop sector specific security assurance requirements.

- b. HBOM, SBOM Reviews. Additionally, vendors must share the HBOMs with specific attention to processors, programmable components and SBOMs related to Open Source and firmware. Traceability of components to source must be possible.
- c. Sovereign standards and certifications. Develop and adopt sovereign testing and certification standards. Test and certify in-country.
- d. Audits under NCIIPC and Dept Oversight. Periodic audits of both the operational processes and the architecture of networks and applications must be done by a team of in-house SMEs.
- e. Blacklists of vendors may be maintained to avoid procurements from vendors whose products have had major security incidents and audit failures in Indian installations.

## 9.2 Use-Case 2: Telecom and Enterprise Class Routers

Routers present perhaps an even more critical vulnerability due to their fundamental role in network infrastructure. They have specialised components like network processors and RF components, with heavy reliance on semiconductor fabrication facilities concentrated in specific global regions. That complicates the supply chain.

As central points of network infrastructure, routers are prime targets for security breaches, with potential impacts cascading throughout connected systems. It could be difficult to identify the exact point of breach in such an interconnected network of systems.

The complexity of their software stack, involving both proprietary and open-source components, creates multiple potential security vulnerabilities. A router security breach can lead to severe consequences across all sectors, including network communications disruption, data breaches, and significant economic losses from network downtime.

No country can totally avoid dependence on foreign supply chains. While developed nations maintain moderate self-sufficiency in basic components, there's still high dependence on foreign semiconductor fabrication.

The industry faces significant challenges in protecting intellectual property related to routing algorithms and security features, even though hardware designs are somewhat protected by their complexity. The software angle here could make it difficult to protect against attacks always, as it is easier to find software backdoors. Critical vulnerabilities stem from dependence on specific chip manufacturers and the limited number of high-end router manufacturers.

Router replacement costs are typically high, especially for enterprise-grade equipment, with substantial additional costs in network reconfiguration and security certification. The situation is particularly concerning given the essential role routers play in modern digital infrastructure, and the limited options for rapid supply chain diversification.

So, overall, the vulnerability score for this product is high, which then would lead to a high SIC, and therefore also affect the RMEQ. The answers to the questions in the appendix could lead to small variations in the RMEQ, but would most probably, because of the SIC multiplier, lead to medium to high RMEQ. Consequently, the recommendations for this use-case would also fall in that category, as can be seen in the table below.

Let's, nevertheless, try answering some questions so as to get an idea of where on the spectrum the costs and benefits fall for this use-case. The implementation costs, like security certification, for securing router supply chains would be very high due to the complex nature of routing technology. Procurement delays, component costs, and supplier substitution costs would also be significantly high due to the specialised nature of router manufacturing and limited supplier options. The threat probability analysis reveals extremely high-risk levels – routers face sophisticated attacks from different actors, and the complexity of their software stack means vulnerabilities are often difficult to patch quickly. The potential breach impact is severe across all dimensions, mainly because routers are the entry

points to networks, plus rerouting can take time, and is sometimes not even possible. Financial losses from router system downtime would be catastrophic, affecting entire networks and dependent systems such as financial systems. Operational disruption would be also extreme, as router failures could paralyse multiple critical systems simultaneously. The reputational damage would be severe and long-lasting, potentially affecting international partnerships and collaborative projects. Compromised routers could expose vast amounts of sensitive data and critical infrastructure systems.

All of this leads to medium to high level of actions to be taken when confronted with hardware supply chain security policy questions, just like in the case of surveillance cameras, though the level of potential impact here is higher.

In the following sections, we have tried putting all of this through our framework to show how this framework is supposed to work, and come up with recommendations for this use-case at the end.

### 9.2.1 Scoring Framework

| Metric                             | Qualitative Analysis                                                                                                                  | Score |
|------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|-------|
| Vulnerability Rating               | Routers exhibit high vulnerability due to complex hardware/software stacks and reliance on a limited number of specialised suppliers. | High  |
| Criticality Rating                 | Deployment in critical sectors (banking, healthcare, government) makes routers essential to network integrity and national security.  | High  |
| Strategic Importance Coefficient   | Reflects high strategic importance based on national impact, replacement difficulty, and geopolitical factors.                        | 0.78  |
| Total Implementation Costs         | High costs related to specialised certification, supply chain audits, and potential procurement delays.                               | 0.7   |
| Threat Probability                 | Elevated risk due to multiple sophisticated attack vectors; patching challenges compound the risk.                                    | 0.8   |
| Breach Impact (Potential Security) | Severe impact across multiple dimensions including financial loss, operational disruption, and national security risks.               | 0.9   |

|                                            |                                                                                                                                                         |      |
|--------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| Potential Harm Prevention (PHV)            | Calculated as Threat Probability $\times$ Breach Impact.                                                                                                | 0.73 |
| Risk Mitigation Efficiency Quotient (RMEQ) | Computed as: $(\text{PHV} / \text{Total Costs}) \times \text{SIC} = (0.73 / 0.7) \times 0.78$ , yielding a value that indicates a very high-risk level. | 0.81 |

Table 7: Scoring Framework

### 1. Strategic Importance Coefficient (SIC) (Overall $\approx 0.78$ )

| Component                      | Qualitative Analysis                                                                             | Weight | Score       |
|--------------------------------|--------------------------------------------------------------------------------------------------|--------|-------------|
| National Impact (NI)           | Breaches can have major national implications given the routers' role in communication networks. | 0.3    | 0.8         |
| Replacement Difficulty (RD)    | Routers are complex systems that are difficult and costly to replace quickly.                    | 0.2    | 0.8         |
| Strategic Vulnerability (SV)   | High vulnerability increases the strategic risk.                                                 | 0.3    | 0.8         |
| Geopolitical Implications (GI) | Dependence on foreign semiconductor manufacturing and related risks contribute moderately.       | 0.2    | 0.7         |
| <b>Overall SIC</b>             |                                                                                                  | —      | $\sim 0.78$ |

Table 8: SIC for Use-Case 2

2. Total Implementation Costs (Overall  $\approx 0.70$ )

| Component                       | Qualitative Analysis                                                     | Weight | Score |
|---------------------------------|--------------------------------------------------------------------------|--------|-------|
| Administrative/Compliance Costs | High costs due to rigorous certification and documentation requirements. | 0.4    | 0.7   |
| Operational Time Costs          | Long delays in procurement and extensive testing elevate costs.          | 0.3    | 0.8   |
| Supplier Substitution Costs     | Limited alternatives and high switching costs increase overall expenses. | 0.3    | 0.6   |
| <b>Overall Costs</b>            |                                                                          | —      | 0.70  |

Table 9: Total Implementation Costs for Use-Case 2

3. Threat Probability (Overall  $\approx 0.80$ )

| Component                         | Qualitative Analysis                                                    | Weight | Score |
|-----------------------------------|-------------------------------------------------------------------------|--------|-------|
| Attack Vectors                    | Routers face multiple sophisticated attack vectors.                     | 0.5    | 0.85  |
| Patching Challenges               | Complex systems lead to significant delays in patching vulnerabilities. | 0.5    | 0.75  |
| <b>Overall Threat Probability</b> |                                                                         | —      | 0.80  |

Table 10: Threat Probability for Use-Case 2

4. Breach Impact (Overall  $\approx 0.91$ )

| Component                    | Qualitative Analysis                                                            | Weight | Score       |
|------------------------------|---------------------------------------------------------------------------------|--------|-------------|
| Financial Impact             | Breaches can result in severe financial losses affecting critical sectors.      | 0.3    | 0.9         |
| Operational Disruption       | Network-wide disruptions can paralyse multiple critical systems simultaneously. | 0.3    | 0.95        |
| Reputational Damage          | Significant harm to corporate and national reputations.                         | 0.2    | 0.9         |
| National Security Impact     | Breaches may compromise national security due to interconnected infrastructure. | 0.2    | 0.85        |
| <b>Overall Breach Impact</b> |                                                                                 | —      | $\sim 0.91$ |

Table 11: Breach Impact for Use-Case 2

An RMEQ of 0.81 falls into the Very High-Risk band (threshold: 0.76–1).

We have earlier described the centrality and importance of routers in today's digital infrastructure. As part of our core recommendation of enforcing sector specific measures, we provide below a qualitative assessment of what market factors and risks are important to consider for various sectors. This is followed by a more detailed set of suggestions on compliance practices to employ.

## 9.2.2 Qualitative Assessment of Criticality

| CONSIDERATIONS ON CRITICALITY BY USE-CASE: ROUTERS |                                      |                                                              |                                                                     |
|----------------------------------------------------|--------------------------------------|--------------------------------------------------------------|---------------------------------------------------------------------|
| Criticality                                        | Context /Deployment                  | Market Factors                                               | Risk Considerations                                                 |
| <b>High</b>                                        |                                      |                                                              | Security of network interfaces in respect to critical lab equipment |
|                                                    | Healthcare Institutions              | Selective supply options                                     | Data Leak Protection for medical data stores                        |
|                                                    | Govt Installations                   | More rigorous deployment processes                           | Separating Classified and Sensitive Assets within the network       |
|                                                    | Oil, Gas, Power, Water Installations | Higher cost of sourcing and support options                  | Supply Chain disruptions                                            |
|                                                    | Banking and Financial Institutions   | Rigorous operational processes / Rigorous acceptance testing | Data Leak Protection                                                |
| <b>Very High</b>                                   | Telecom Installations                | Limited options of sources                                   | Local Standards where gaps exist                                    |

|  |                                              |                                            |                                                                                                              |
|--|----------------------------------------------|--------------------------------------------|--------------------------------------------------------------------------------------------------------------|
|  | Nuclear plants                               | High standards and specs                   | Redundancy in components<br><br>Design flaws can be catastrophic. HLDs and LLDs to cater for fault tolerance |
|  | Defence Installations                        | Higher cost lifecycle                      | Air-gaps by design; supplier sources validated by site inspections                                           |
|  | Strategic Tech Research, Manufacturing Units | Customised Sensitive Operational Processes | Security of the data assets; security of IP data in store                                                    |

Table 12: Use-Case 2 – Routers – Analysis and Recommendations

Please notice that Table 2 has only two tiers of criticality as against Table 1 which had three tiers. For Table 1, the product under consideration is highly vulnerable. Still, a majority of its use cases are in Low Criticality segments given that the products are typically deployed in the non-critical, universal use infrastructure segment. On the other hand, in Table 2, the product under

consideration is a Router and is highly vulnerable and most of its use cases are in the High and Very High Criticality segments and further in the National Critical Infrastructure segment where impacts are severe.

Recommended policies would include measures such as:

1. Setting up a Sectoral Security Assurance Committee for each sector. The concerned Ministry may host the functions and proceedings of the Committee with SMEs called in from the academia, research and industry associations.
2. All the products need to be tested and certified before induction into networks. Appropriate validity of these certificates may be applied considering the need for software and hardware to undergo upgrades in their life cycles.
3. Develop sector specific security assurance requirements and product security requirements.
4. Limiting procurement to security-cleared vendors and embedding liability clauses for breaches.

Based on the criticality of each sector use-case, we identify a few additional compliance measures:

1. **High Criticality Sectors** (Govt General, Healthcare, Utilities, Banking and Financials)
  - a. Survey the market and empanel or shortlist a panel of vendors who are security cleared.

- i. Audit the transparency in governance of the vendor company.
  - ii. Test the design/manufacturing/supply chain practices of the company.
- b. Rely on globally accepted testing and certification standards.
- c. Disclosure of Supply Chains: The vendor must commit to disclosing their supply chains (manufacturing locations, distribution channels, and market partners' details)
- d. HBOM, SBOM Reviews: Carry out BOM reviews for sensitive components in the supply chain.
- e. Ensure the user institutions have rigorous operational processes from acceptance of products to end-of-life.
- 2. **Very High Criticality Sectors** (Defence, Nuclear, Strategic Research Institutions and Related Manufacturing Sites)
  - a. Secure by Design Reviews. Every router class that is considered for procurement must have a Secure-By-Design Review done in partnership with the vendor.
  - b. In addition to HBOM/SBOM reviews, vendors must share the HBOMs with specific attention to processors, programmable components and SBOMs related to Open Source and firmware. Traceability of components to source must be possible.
  - c. Sovereign standards and certifications. Develop and adopt sovereign testing and certification standards. Test and certify in-country.

- d. Liability: Liability clauses in major and large deals to cover breaches of a certain scale may be included in the contracts.
- e. Audits under NCIIPC and Dept Oversight. Periodic audits of both the operational processes and the architecture of networks and applications must be done by a team of in-house SMEs.
- f. Blacklists of vendors may be maintained to avoid procurements from vendors whose products have had major security incidents and audit failures in Indian installations.

## 10. Conclusion

There is a critical need for a transformative, data-driven approach to electronic hardware supply chain security policies. By moving beyond fragmented, static regulatory frameworks to a dynamic, quantitative assessment and cost-benefit analysis methodology, we can more effectively balance technological feasibility, national security, and economic interests. The aim is to prioritise adaptable risk management over rigid compliance.

## 11. Appendix

The proposed Hardware Supply Chain Security (HSCS) framework proposes an approach that aims to create a comprehensive, quantitative methodology for evaluating policies and their impact in the case of hardware supply chain security. Unlike existing policies that rely on subjective assessments, this framework provides a mathematically rigorous mechanism to calculate strategic importance, potential harm, and implementation costs through precise coefficients and multi-dimensional scoring mechanisms.

The framework's core innovation lies in its Risk Mitigation Efficiency Quotient (RMEQ), which synthesises harm prevention value, implementation costs, and strategic importance of sectors/use cases into a single, actionable metric. It requires an assessment of the criticality of a sector or use-case, and of the vulnerability of a product, to normalise the benefits and costs of a policy intervention. By integrating nuanced factors like geopolitical implications, threat probabilities, and potential breach impacts, the framework enables policymakers and technology strategists to make data-driven decisions about hardware supply chain security, transforming risk assessment from a qualitative exercise to a sophisticated, evidence-based analytical process.

In the following sections, we discuss the parameters that are important in this quantitative assessment framework, and propose some indicative questions that need to be answered to come up with reasonable estimates for these parameters. We also propose some equations that we think could be used reasonably well to carry out this cost-benefit analysis. However, we acknowledge that there could be various other forms of these equations. The focus of this paper is on the questions that need to be asked and the parameters that are important in this analysis, instead of focussing on what the mathematical equations should be. The thrust of the paper is on achieving a cost-benefit analysis of the various product-use case scenarios, normalise this analysis based on the strategic importance of the context, and factor in the criticality of the sector and the vulnerability of the product into the calculations to come up with what should be the form and severity of the policy intervention. What mathematical form this entire exercise takes is left open. We propose one such form in this appendix, but that is just an indicative suggestion.

Let's look at how the analysis should progress. It should begin by identifying where a specific combination of product and use-case lies around the concepts of criticality of the use-case or the sector, and the overall vulnerability score we might apply to that particular product's supply chain security. This would help identify the Strategic Importance Coefficient (SIC) - which is detailed in the following sections - for the use-case which would be used to normalise the costs and harm prevention value that we identify later in the analysis. This

normalisation is important to make sure that the specific context of the use-case, sector and product is properly accounted for in the analysis.

The above three parameters – SIC, costs and harm prevention value – would then feed into the formulae to calculate the Risk Mitigation Efficiency Quotient (RMEQ) which would basically help indicate what should be the type and severity of any policy intervention.

In the following section, let's look at the framework of Criticality (of a sector or use-case) vs Vulnerability of the product or its supply chain, which gives us four quadrants, as shown in figure 5 below.

## 11.1 Criticality-Vulnerability Classification

### Framework

Whenever a product-use-case (product-sector) scenario is to be analysed to come up with policy measures, we propose that the following framework be used to come up with targeted measures, instead of one-size-fits-all broad policy actions. The idea is to recognise that the same product in different sectors and use cases or contexts will have different criticality dimensions. Also, the product will have its own vulnerabilities (substitutability, etc.) in its supply chain, which will help inform the strategic importance of the specific product-use-case scenario.

Thus, the criticality axis is for the use-case or sector, while the vulnerability axis is for the product itself. A cross of these two dimensions helps in coming up with the strategic importance of the scenario – one of high, medium and low strategic importance. This measure then will help one come up with a Strategic Importance Coefficient for the particular scenario, which can be used in the quantitative assessment framework proposed in the next sections as a normalising factor.

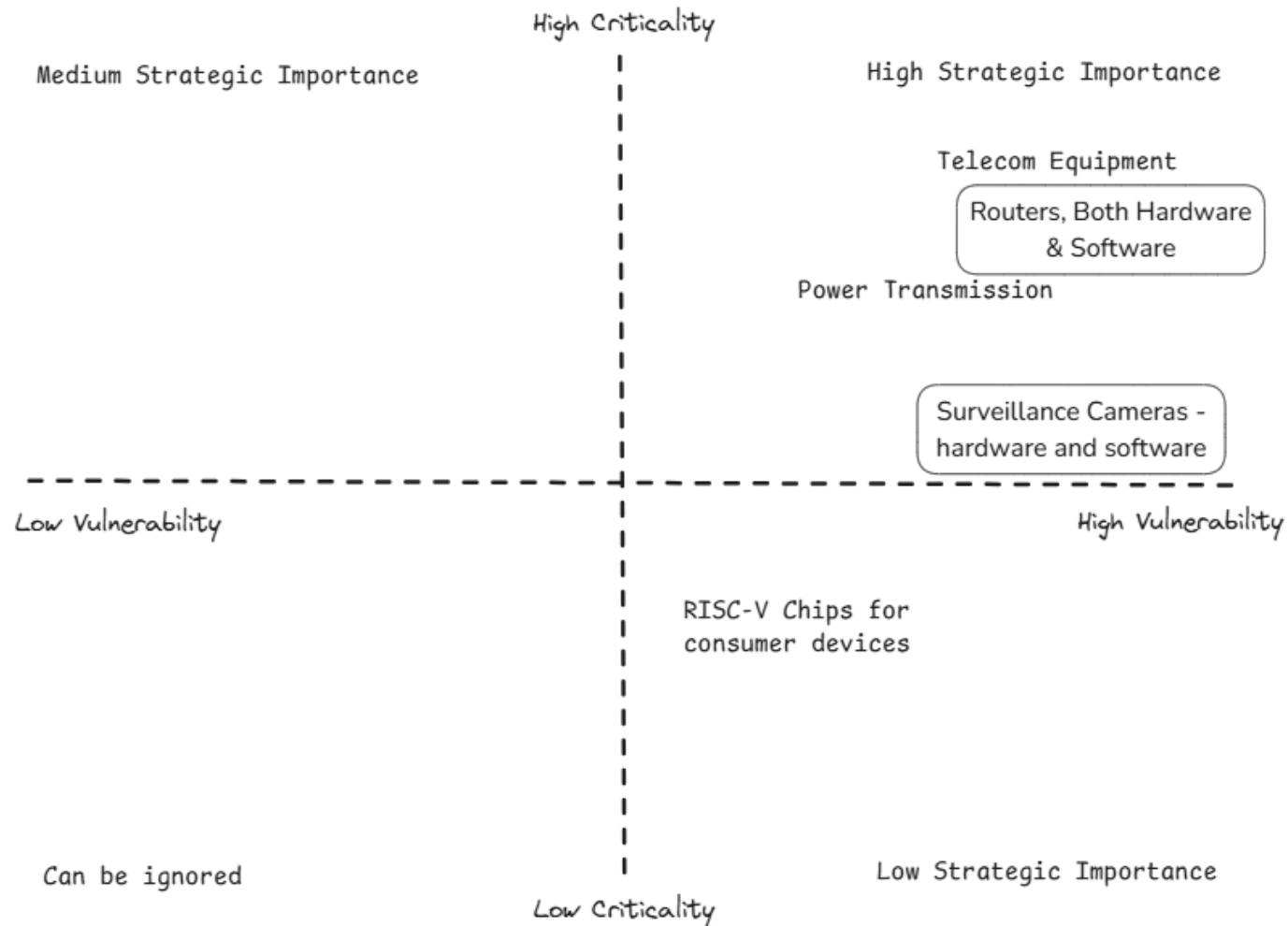


Figure 5: Criticality-Vulnerability Classification Framework

The two products, as examples, reflected in the Figure 5 above are Surveillance Cameras and Routers. They are placed differentially on the

Vulnerability axis for reasons that products are vulnerable on account of cybersecurity exposures due to their architecture, design and the components within. This differentiation is described in section 9 where we consider these two use cases.

### 11.1.1 What is Criticality?

Criticality measures the impact of a supply chain attack on a given sector across multiple dimensions. We have created a set of criteria below (not in any specific order) that help the reader arrive at qualitative assessments of the criticality of a sector:

Impact of a supply chain attack on the sector:

1. Disruption of key critical civilian infrastructure
2. Disruption of multiple downstream sectors
3. Loss of life or loss of societal order
4. Interruption of societal or market activity
5. Disruption to key national security infrastructure

The criticality of a given use-case determines the extent of regulation or intervention we should accept in the policy.

### 11.1.2 What is Vulnerability?

Vulnerability in a supply chain account arises from two different factors. First, there are chances of disruption in the functioning of an industry due to geopolitical or natural events. The direct short-term impact is economic, while there may be indirect losses regarding long-term industrial capability and spillover effects on society. The second factor is security vulnerabilities in a supply chain, where opponents may be able to infiltrate and take control of aspects of the supply chain with similar effects to the first cause, except under a deterministic timeline under their control.

While the mitigation steps for both causes may overlap, they also have some conflicting situations. For example, to improve resilience in an industry supply chain, we may prefer diversification and higher competition (smaller players, where our power as clients improve), but from a security perspective, we should prefer less diversified and more focused supply chains, which reduce the surface area of attack.

Here, we define vulnerability as a qualitative assessment of the likelihood of a security breach for a particular use-case or in a specific sector. This is likely to be multimodal and is affected by factors as varied as technological self-sufficiency to the complexity of the supply chain (likely to be inverse to self-sufficiency). We provide below a set of possible considerations for evaluating vulnerability in a product:

1. The complexity of the supply chain – Long chains with many vendors and subsystems spread globally, makes it more vulnerable. The optimisation aimed for in purchase or service agreements is generally for factors like assured delivery and for having the product cost not above the lowest in market. However, long supply chains could mean lesser traceability. Also, while a long supply chain might hint towards the possibility of high substitutability, a long supply chain with internal choke points which are single points of failure for a particular large component, is not, in effect, a supply chain with high substitutability. Hence, supply chain network graphs need to be analysed keeping in mind the leverage and choke points.
2. Connectedness of technology – The trend in new technologies is to become network-centric (IOT), which allows subsystems to communicate with networks actively. We should prefer passive, non-connected hardware over connected hardware from a security perspective.
  - a. Component Programmability – The ability to re-program hardware subsystems through firmware updates could be a point of failure, especially since this may introduce backdoors long after the system has been put in place.
3. Recovery/restoration complexity:
  - a. How significant is the loss of capability in a sector/industry?
  - b. How significant are the spillover effects?

4. Self-sufficiency – How much of the supply chain is directly under our control?
5. Preventing IP theft – How do we protect the IP embedded in our supply chain? This has longer-term implications for security (and resilience) as stolen IP can be used to create alternatives that ultimately create competition and diversity in supply, decreasing security.
6. Potential single points of failure – Does the product itself have replacements? Potential for reverse engineering.
7. Replacement/redundancy costs

Use cases that rank low on both vulnerability and criticality (LC-LV) can be ignored safely. They don't need any specific policy as such, and if at all there has to be some policy, it can be the least restrictive and punitive.

The cases that need to be considered are **High Criticality-High Vulnerability (HC-HV)**, **High Criticality-Low Vulnerability (HC-LV)**, and **Low Criticality-High Vulnerability (LC-HV)**. Any case that has at least one of the two dimensions ranked high, merits a specific policy. However, criticality of a sector being high will merit a higher score in severity for the product-sector use-case because of the potential impact of disruption. For instance, in a sector which ranks low on criticality, even a product with high vulnerability will not cause a lot of disruption, and hence the remedial policy actions in such a scenario can be less severe, and can even be spread out over a longer term. This is why the above three cases are labelled as follows:

HC-HV - High Strategic Importance

HC-LV - Medium Strategic Importance

LC-HV - Low Strategic Importance

As mentioned above, the LC-LV case can be ignored.

This paper posits that before coming up with policies, the criticality of the sector, and the product's vulnerability needs to be analysed to come up with the strategic importance score of that use-case. Here, either a category of products or individual products can be considered; a category of products might be an easier approximation and exercise to perform. This will then be used to come up with the Strategic Importance Coefficient for the use-case, as described in the next section.

In the next section, let's look at some questions that can be asked to come up with quantitative parameters that can be used as proxies for these classifications.

## 11.2 Strategic Importance Coefficient

Based on the above classification, each sector or sub-sector or use-case being considered for policymaking will need to be assigned a Strategic Importance Coefficient (SIC). This could be assigned within a range (0-1) and to come

up with this coefficient, the factors to be considered should be national impact, replacement difficulty, strategic vulnerability and geopolitical implications. Each of these factors could have different weights assigned to them. The idea here is to understand the strategic importance of a sector or use-case, and use that to normalise the final cost-benefit analysis that is to be done as part of this framework to arrive at a measure of the severity of the required policy measure.

We suggest that the formula for SIC could be the following:

$$\text{SIC} = (\text{NI} \times \text{W}_1) + (\text{RD} \times \text{W}_2) + (\text{SV} \times \text{W}_3) + (\text{GI} \times \text{W}_4)$$

Where:

NI = National Impact

RD = Replacement Difficulty

SV = Strategic Vulnerability

GI = Geopolitical Implications

W<sub>1</sub>-W<sub>4</sub> = Weighted Importance Factors (Total = 1)

However, more important than the actual equation used in this quantitative assessment, let's look at some questions that can help in coming up with values for these various factors. Again, since the value for SIC is to be within

the range 0 to 1, the values for these factors will also have to be within this range when multiplied by the weighing factors.

### **11.2.1 National Impact (NI)**

This measures the potential national disruption. The questions to be answered are:

1. What is the estimated total economic disruption if this infrastructure/technology fails? Is it High = Catastrophic, Severe, or Low = Marginal?
2. How many downstream systems would be immediately affected by a failure? Most, Many, Few

### **11.2.2 Replacement Difficulty (RD)**

Measures complexity of replacing the infrastructure.

1. How many years of specialised knowledge are required to recreate this technology?
2. What percentage of required manufacturing capabilities currently exist domestically?
3. What is the estimated R&D investment needed for complete technological replication? Significant, Incremental-Within-Present-Capacity.

### 11.2.3 Strategic Vulnerability (SV)

Quantifies potential exploitation risks.

1. What is the historical frequency of attempted exploits for similar technologies? (incidents/year) Rare, Often, Very-Frequent.
2. How many known potential attack vectors exist? Many, Some, Few.
3. What is the geopolitical threat level for this specific technological domain? High, Medium, Low.

### 11.2.4 Geopolitical Implications (GI)

Assesses broader strategic significance.

1. What is the estimated economic value of this technology in international markets?
2. How many strategic sectors would be impacted by technology leadership in this domain?
3. What is the diplomatic sensitivity score for technology transfer?

## 11.3 Cost-Benefit Analysis

A methodical and detailed cost-benefit analysis (CBA) needs to be performed for the product and the sector being considered for policymaking initiative.

This CBA will weigh the Total Implementation Costs against the Harm Prevention Value (HPV) of the policy being suggested.

Now let's look at questions that can be asked to come up with the values that feed into the above-mentioned analysis.

### 11.3.1 Total Implementation Costs

1. Administrative Expenses: What are the total administrative compliance expenses? Very High, High, Medium, Low.
2. Operational Time Costs: What is the opportunity cost of procurement delays? Very High, High, Medium, Low.
3. Component Cost Increase: What percentage premium would secure components cost? <Give %>.
4. Supplier Substitution Costs: What are the costs of substituting suppliers - domestically and internationally? Very High, High, Medium, Low.

Some detailed questions on each of these could be framed along the following lines. However, these are not meant to be exhaustive. And their values are not to be in monetary terms, rather they need to be in a range that indicates the severity or magnitude of these factors, so as to be able to fit into the formula. There would be weighing factors that would normalise each of these anyway.

Administrative Expenses:

1. Total staff-hours required for compliance documentation?
2. External audit fees for security certification?
3. Training program development costs?
4. Hourly rate for compliance personnel?

Operational Time Costs:

1. Estimated procurement delay duration (weeks/months)?
2. Productivity loss severity during certification process?
3. Additional resource allocation costs for supplier vetting?
4. Opportunity cost of delayed technology implementation?

Component Cost Increase:

1. Base component current market price?
2. Estimated security compliance premium percentage?
3. Technology specialisation complexity score?
4. Projected geopolitical constraint impact on pricing?

Supplier Substitution Costs:

1. Estimated R&D investment for technology adaptation?
2. Supplier qualification process total expenses?
3. Initial production setup capital requirements?
4. Technology transfer/knowledge acquisition costs?

### 11.3.2 Potential Harm Prevention (PHV)

This will be a product of Threat Probability and Potential Security Breach Impact. These parameters are explained in the following sections.

This paper's proposed equation for calculating PHV is:

Potential Harm Prevention = (Threat Probability) × (Potential Security Breach Impact)

#### 11.3.2.1 Threat Probability

This is a numerical representation of the likelihood of a security breach. It should be assigned a value that scales from 0 to 1 (or 0% to 100%).

The equation for this would be:

Threat Probability = (Number of Potential Attack Vectors) / (Total Possible Mitigation Strategies) × Historical Breach Rate

This will be calculated based on:

- Historical attack patterns
- Vulnerability assessments
- Threat intelligence

- Geopolitical risk factors

The questions to be asked for this factor could be:

- What are all the potential threats in a particular “product \* use-case” category?
- What are all the possible mitigation strategies? Do we have them well-defined?
- How many historical breach attempts have occurred?
- What percentage of known vulnerabilities remain unpatched?
- What is the estimated sophistication level of potential threat actors?

Let’s look at some Threat Probability expanded parameters. These are not exhaustive, merely indicative.

Quantitative Threat Assessment:

1. Number of successful historical breaches in similar systems?
2. Average time between vulnerability discovery and patching?
3. Percentage of known vulnerability vectors unaddressed?
4. Estimated attacker resource investment capability?

Geopolitical Threat Factors:

1. Number of state/non-state actors with potential interest?
2. Technological sophistication of potential threat actors?

3. Geopolitical tension related to the technology domain?

#### Systemic Vulnerability Metrics:

1. Number of potential attack surface entry points?
2. Complexity of potential exploit mechanisms?
3. Estimated system recovery time after theoretical breach?
4. Cross-system contamination potential?
5. Average breach mitigation response time?

#### 11.3.2.2 Potential Security Breach Impact

This quantifies the potential damage from a successful security breach. Again, this will not be a monetary value, but rather will have to be visualised after normalisation as a value within a range that fits into the overall formula for CBA. It would most preferably be within a range from 0 to 1.

It must be measured across multiple dimensions to be comprehensive. Some indicative dimensions are laid out below:

- Financial Losses
- Operational Disruption
- Reputational Damage
- National Security Implications

A suggested Impact Scoring Matrix (to quantify the impacts across dimensions) and an equation to calculate the Potential Security Breach Impact could be as follows.

Impact Scoring Matrix:

An impact scoring matrix across various dimensions could be the following:

| Impact Dimension       | Low | Medium | High | Critical |
|------------------------|-----|--------|------|----------|
| Financial Loss         | 1-2 | 3-5    | 6-8  | 9-10     |
| Operational Disruption | 1-2 | 3-5    | 6-8  | 9-10     |
| Reputational Damage    | 1-2 | 3-5    | 6-8  | 9-10     |
| National Security Risk | 1-2 | 3-5    | 6-8  | 9-10     |

Figure 7: Impact Scoring Matrix

Comprehensive Impact Calculation:

Potential Security Breach Impact =  $\Sigma(\text{Weighted Scores Across Impact Dimensions}) / \text{Total Possible Score}$

### 11.3.2.3 Example Calculation

Let's look at critical defence communication infrastructure as an example, using the formulas listed above, to get a better understanding of how this framework would work.

Threat Probability: 0.4 (40% chance of breach)

Impact Scores:

Financial Loss: 8/10

Operational Disruption: 9/10

Reputational Damage: 7/10

National Security Risk: 9/10

Calculation:

Potential Security Breach Impact =  $((8 + 9 + 7 + 9) / 40) = 0.825$

Potential Harm Prevention =  $0.4 \times 0.825 = 0.33$

What could be some questions that can better inform the formulation of these parameters? Let's look at some.

Financial Losses:

1. What is the estimated direct financial loss per hour of system downtime?
2. What percentage of annual revenue could be compromised?
3. Potential litigation or compensation costs?
4. Estimated cybersecurity recovery and remediation expenses?

Operational Disruption:

1. How many critical systems would be simultaneously impacted?
2. Estimated recovery time (hours/days) to full operational capacity?

3. Percentage of operational capabilities that would be non-functional?
4. Number of critical processes that would be immediately halted?

Reputational Damage:

1. Number of strategic partnerships potentially at risk?
2. Projected recovery timeline in months?
3. Projected technology leadership ranking change?
4. Estimated R&D investment setback?
5. Number of international collaborative projects potentially cancelled?
6. Projected innovation ecosystem disruption score?

National Security Risk:

1. Number of sensitive national infrastructure systems potentially compromised?
2. Estimated strategic information exposure level?
3. Potential geopolitical escalation probability?
4. Number of classified/protected information segments at risk?

## 11.4 Risk Mitigation Efficiency Quotient (RMEQ)

The Risk Mitigation Efficiency Quotient (RMEQ) measures the effectiveness of security investments by comparing the potential harm

prevented against the total implementation costs, weighted by the strategic importance of the system. It provides a normalised score that helps decision-makers evaluate the value of security interventions relative to their complexity and strategic significance.

To arrive at the RMEQ, the CBA value has to be multiplied by the SIC to get a normalised value for the CBA. Normalising using the SIC is important to ensure that the strategic importance of the particular product-use case combination is factored into the analysis, so as to prevent applying a one-size-fits-all approach to all scenarios without considering the context.

The formula would look something like this:

$$\text{RMEQ} = [\text{Harm Prevention Value}] / [\text{Total Implementation Costs}] \times [\text{Strategic Importance Coefficient}]$$

Again, as mentioned previously, this is only a suggested formula. There could be other forms of this equation that could better capture the complexities involved.

The above exercise should give a value for RMEQ between 0 and 1. This value will then influence the severity and details of the policy being considered.

The scale for RMEQ would be:

Low: 0–0.25

Medium: 0.26–0.5

High: 0.6–0.75

Very High: 0.76–1

As already mentioned in section 8, corresponding to each scale range, the actions recommended are:

**Low Risk (No Restrictions) Approach:** In scenarios with minimal security risks, hardware supply chain policies adopt a lightweight, non-interventionist stance. Organisations can procure and integrate technologies with standard market protocols, without additional regulatory overhead. The focus remains on maintaining normal market dynamics, trusting existing quality control mechanisms and standard industry practices. These environments typically represent stable technological ecosystems with predictable supply chain behaviours and low potential for strategic disruption.

**Medium Risk (Voluntary Certification) Strategy:** When potential vulnerabilities emerge, a balanced regulatory approach takes precedence. Voluntary certification programs are introduced, creating standardised security assessment frameworks without mandating strict ex-ante compliance. Organisations receive incentives to participate in security audits,

with retrospective verification mechanisms. Soft enforcement through penalty provisions encourages proactive risk management. This approach transforms security from a compliance burden to a collaborative improvement process, allowing flexibility while establishing clear accountability standards.

**High Risk (Trust but Verify) Protocol:** As technological and geopolitical risks intensify, a more stringent "trust but verify" model becomes critical. Comprehensive ex-ante checks are implemented before technology integration, focusing on pre-emptive risk identification. Whitelisting becomes a key strategy, where only pre-verified technologies, suppliers and points of origin gain market access. Extensive due diligence, including detailed supply chain mapping, technological vulnerability assessments, and rigorous certification processes, becomes mandatory. The approach balances openness with strategic prudence.

**Very High Risk (Restrictive) Response:** In scenarios of extreme strategic vulnerability, hardware supply chain policies transition to a protective, exclusionary model. Access is systematically restricted from nations or entities deemed high-risk, utilising comprehensive blacklisting mechanisms. Critical technologies face complete blockades, with multi-layered screening preventing potential technological infiltration. National security considerations override market considerations, creating a fortress-like

approach to technological sovereignty. The primary objective shifts from market optimisation to strategic defence and technological independence.

## 12. References

- <sup>1</sup> Reuters, "Pager Attack Threw Hezbollah into Disarray", September 18, 2024, <https://www.reuters.com/world/middle-east/pager-attack-threw-hezbollah-into-disarray-2024-09-18/>.
- <sup>2</sup> Fortinet, "What Was the SolarWinds Cyber Attack?", Accessed March 4, 2025, <https://www.fortinet.com/resources/cyberglossary/solarwinds-cyber-attack>.
- <sup>3</sup> IBM, "Log4j Vulnerability Explained", IBM Think, Accessed February 19, 2025, <https://www.ibm.com/think/topics/log4j>.
- <sup>4</sup> Cybersecurity and Infrastructure Security Agency, "Executive Order 14017: Securing America's Supply Chains", Accessed March 4, 2025, <https://www.cisa.gov/executive-order-14017-securing-americas-supply-chains>.
- <sup>5</sup> US Congress, CHIPS and Science Act of 2022, H.R. 4346, 117th Congress (2022), Accessed March 4, 2025, <https://www.congress.gov/bill/117th-congress/house-bill/4346>.
- <sup>6</sup> ActiveMind Legal, "EU Supply Chain Directive: A Comprehensive Guide", Accessed March 4, 2025, <https://www.activemind.legal/guides/eu-supply-chain-directive/>.
- <sup>7</sup> European Union, "Regulation (EU) 2024/2847 of the European Parliament and of the Council", EUR-Lex, Accessed March 4, 2025, <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32024R2847>.
- <sup>8</sup> National Cyber Security Centre, "Supply Chain Security Guidance", Accessed March 4, 2025, <https://www.ncsc.gov.uk/collection/supply-chain-security>.

<sup>9</sup> UK Government, "Defence Cyber Protection Partnership", Accessed March 4, 2025, <https://www.gov.uk/guidance/defence-cyber-protection-partnership>.

<sup>10</sup> UK Government, "Common Criteria For Assessing Risk (CCFAR)", Accessed March 4, 2025, [https://assets.publishing.service.gov.uk/media/5a80081ae5274a2e8ab4dc76/Common\\_Criteria\\_For\\_Assessing\\_Risk\\_CCFAR\\_Final\\_2.0.pdf](https://assets.publishing.service.gov.uk/media/5a80081ae5274a2e8ab4dc76/Common_Criteria_For_Assessing_Risk_CCFAR_Final_2.0.pdf).

<sup>11</sup> UK Government, "Telecommunications Security Bill Collection", Accessed March 4, 2025, <https://www.gov.uk/government/collections/telecommunications-security-bill>.

<sup>12</sup> UK Government, "The Electronic Communications (Security Measures) Regulations 2022: Explanatory Memorandum", Statutory Instrument 2022 No. 933, Accessed March 4, 2025, [https://www.legislation.gov.uk/ukxi/2022/933/pdfs/ukxiem\\_20220933\\_en.pdf](https://www.legislation.gov.uk/ukxi/2022/933/pdfs/ukxiem_20220933_en.pdf).

<sup>13</sup> UK Government, "Telecommunications Security Code of Practice", Department for Digital, Culture, Media & Sport, December 2022, Accessed March 4, 2025, [https://assets.publishing.service.gov.uk/media/6384d09ed3bf7f7eba1f286c/E02781980\\_Telecommunications\\_Security\\_CoP\\_Accessible.pdf](https://assets.publishing.service.gov.uk/media/6384d09ed3bf7f7eba1f286c/E02781980_Telecommunications_Security_CoP_Accessible.pdf).

<sup>14</sup> Department of Telecommunications, Government of India, "Compliance of Amendment in License Conditions Regarding National Security Directive on Telecommunication", Accessed March 4, 2025, <https://dot.gov.in/dataservices/compliance-amendment-license-conditions-national-security-directive-telecommunication>.

<sup>15</sup> National Centre for Communication Security, "COMMUNICATION SECURITY CERTIFICATION SCHEME", Government of India, Accessed March 4, 2025, [https://nccs.gov.in/public/downloads\\_scheme/E1\\_2.pdf](https://nccs.gov.in/public/downloads_scheme/E1_2.pdf).

<sup>16</sup> Press Information Bureau (PIB), Government of India, "Restrictions on Public Procurement from certain countries", July 23, 2020, Accessed March 4, 2025, <https://pib.gov.in/PressReleasePage.aspx?PRID=1640778>.

<sup>17</sup> 3rd Generation Partnership Project (3GPP), "Home", Accessed March 4, 2025, <https://www.3gpp.org/>.



The Takshashila Institution is an independent centre for research and education in public policy. It is a non-partisan, non-profit organisation that advocates the values of freedom, openness, tolerance, pluralism, and responsible citizenship. It seeks to transform India through better public policies, bridging the governance gap by developing better public servants, civil society leaders, professionals, and informed citizens.

Takshashila creates change by connecting good people, to good ideas and good networks. It produces independent policy research in a number of areas of governance, it grooms civic leaders through its online education programmes and engages in public discourse through its publications and digital media.